



Cyber Security (CYBER); CRA ; Cybersecurity requirements for boot managers

Exercising one of the Principles of international standardization - Openness - and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit: [STAN4CRA / EN 304 623 Boot managers · GitLab](#) and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

ReferenceDEN/CYBER-EUS-008

KeywordsCRA, Cybersecurity, Boot

0

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

Reproduction is only permitted for the purpose of standardization work undertaken within ETSI.
The copyright and the foregoing restrictions extend to reproduction in all media.

© ETSI 2025.
All rights reserved.

Contents

1	Intellectual Property Rights	10
2	Foreword.....	10
3	Modal verbs terminology	11
4	Introduction	11
5	1 Scope	12
6	1.1 General.....	12
7	1.2 In-scope products.....	12
8	2 References	13
9	2.1 Normative references	13
10	2.2 Informative references	13
11	3 Definition of terms, symbols and abbreviations.....	14
12	3.1 Terms	14
13	3.2 Symbols	16
14	3.3 Abbreviations.....	17
15	4 Product description.....	17
16	4.1 Intended purpose and reasonably foreseeable use	17
17	4.1.1 Intended purpose	17
18	4.1.2 Reasonably foreseeable use.....	17
19	4.1.3 Reasonably foreseeable misuse	18
20	4.2 Product functions.....	18
21	4.3 Architecture	19
22	4.3.1 Boot architecture	19
23	4.3.1.1 Unverified boot.....	19
24	4.3.1.2 Verified boot.....	19
25	4.3.1.3 Measured boot	20
26	4.3.2 Functional extensions.....	20
27	4.3.3 Product capabilities	20
28	4.3.3.0 Introduction.....	20
29	4.3.3.1 Update capability.....	20
30	4.3.3.2 Boot source.....	21
31	4.3.3.3 Configuration management	21
32	4.3.3.4 Hardware security.....	22
33	4.3.3.5 Recovery capability	22
34	4.3.3.6 Logging capability.....	22
35	4.3.3.7 Authentication capability.....	22
36	4.3.3.8 Debug interface	23
37	4.3.4 Resource constraints.....	23
38	4.4 Operational environment	23
39	4.4.1 Introduction.....	23
40	4.4.2 Physical security context.....	23
41	4.4.3 Network exposure	24
42	4.4.4 Data sensitivity and value	24
43	4.4.5 System criticality	24
44	4.4.6 Lifecycle expectations.....	24
45	4.4.7 Administrative control.....	24
46	4.4.8 Availability requirements.....	25
47	4.4.9 Additional environmental characteristics	25
48	4.4.9.1 Power supply	25
49	4.4.9.2 Environmental stress.....	25
50	4.4.9.3 Update frequency expectations.....	25
51	4.4.9.4 Interfaces	26
52	4.5 Distribution of security functions	26
53	4.5.1 Introduction.....	26
54	4.5.2 Security functions provided by the boot manager	26
55		

56	4.5.3	Security functions required from the platform	27
57	4.5.4	Security functions delegated to boot target	27
58	4.5.5	Trust boundaries.....	27
59	4.5.6	Relation to other vertical CRA standards.....	28
60	4.6	Users	28
61	4.6.1	Introduction	28
62	4.6.2	User categories.....	28
63	4.6.3	User interaction patterns.....	28
64	4.7	Risks, threats and security context.....	29
65	4.7.1	General.....	29
66	4.7.2	Confidentiality.....	29
67	4.7.3	Integrity.....	30
68	4.7.4	Availability.....	30
69	4.7.5	Impact of other devices	30
70	4.7.6	Assets requiring protection.....	30
71	4.7.6.1	A-CRYPT: Cryptographic keys and certificates.....	30
72	4.7.6.2	A-ROLLBACK: Rollback protection data	31
73	4.7.6.3	A-CONFIG: Configuration data	31
74	4.7.6.4	A-AUTH: Authentication credentials.....	31
75	4.7.6.5	A-MEASURE: Measurement and attestation data	31
76	4.7.6.6	A-AUDIT: Audit logs.....	32
77	4.7.6.7	A-RUNTIME: Runtime state data	32
78	4.7.6.8	A-CODE: Boot manager executable code.....	32
79	4.7.6.9	A-UPDATE: Update packages and delivery mechanisms.....	32
80	4.7.7	Threat categories	33
81	4.7.7.0	Introduction to threat categories	33
82	4.7.7.1	T-INTEGRITY: Boot integrity attacks.....	33
83	4.7.7.2	T-PERSIST: Persistent firmware threats	33
84	4.7.7.3	T-PHYS: Physical attacks	33
85	4.7.7.4	T-SUPPLY: Supply chain attacks	33
86	4.7.7.5	T-NET: Network-based attacks	33
87	4.7.7.6	T-AVAIL: Availability and resilience threats	33
88	4.7.8	Risk factors	34
89	4.7.8.0	Introduction to risk factors.....	34
90	4.7.8.1	Impact factors.....	34
91	4.7.8.2	Likelihood factors.....	34
92	4.7.8.3	Risk level determination	35
93	4.8	Representative use cases	36
94	4.8.1	Purpose.....	36
95	4.8.2	UC-L1: Immutable embedded.....	36
96	4.8.3	UC-L2: Updateable IoT and consumer	36
97	4.8.4	UC-M1: Consumer and SMB computing.....	36
98	4.8.5	UC-M2: Enterprise managed.....	36
99	4.8.6	UC-H1: Critical systems	37
100	4.8.7	Use case capabilities.....	37
101	4.8.8	Use case selection	37
102	5	Requirements.....	38
103	5.1	Requirement framework	38
104	5.2	Security by Design.....	38
105	5.2.0	Introduction to Security by design requirements	38
106	5.2.1	[RQ-SBD-001]	38
107	5.2.2	[RQ-SBD-002]	38
108	5.2.3	[RQ-SBD-003]	38
109	5.2.4	[RQ-SBD-004]	39
110	5.2.5	[RQ-SBD-005]	39
111	5.3	Secure by Default Configuration	39
112	5.3.0	Introduction to secure by default configuration requirements	39
113	5.3.1	[RQ-DEFAULT-001].....	39
114	5.3.2	[RQ-DEFAULT-002].....	39
115	5.3.3	[RQ-DEFAULT-003].....	39
116	5.3.4	[RQ-DEFAULT-004].....	39

117	5.3.5	[RQ-DEFAULT-005].....	40
118	5.3.6	[RQ-DEFAULT-006].....	40
119	5.4	Authentication and Authorization.....	40
120	5.4.0	Introduction to authentication and authorization requirements.....	40
121	5.4.1	[RQ-AUTH-001].....	40
122	5.4.2	[RQ-AUTH-002].....	40
123	5.4.3	[RQ-AUTH-003].....	40
124	5.4.4	[RQ-AUTH-004].....	40
125	5.4.5	[RQ-AUTH-005].....	41
126	5.4.6	[RQ-AUTH-006].....	41
127	5.4.7	[RQ-AUTH-007].....	41
128	5.5	Confidentiality	41
129	5.5.0	Introduction to confidentiality requirements.....	41
130	5.5.1	[RQ-CONFID-001].....	41
131	5.5.2	[RQ-CONFID-002].....	41
132	5.5.3	[RQ-CONFID-003].....	41
133	5.5.4	[RQ-CONFID-004].....	42
134	5.5.5	[RQ-CONFID-005].....	42
135	5.5.6	[RQ-CONFID-006].....	42
136	5.5.7	[RQ-CONFID-007].....	42
137	5.5.8	[RQ-CONFID-008].....	42
138	5.6	Integrity Protection	42
139	5.6.0	Introduction to integrity protection requirements	42
140	5.6.1	[RQ-INTEGRITY-001].....	42
141	5.6.2	[RQ-INTEGRITY-002].....	43
142	5.6.3	[RQ-INTEGRITY-003].....	43
143	5.6.4	[RQ-INTEGRITY-004].....	43
144	5.6.5	[RQ-INTEGRITY-005].....	43
145	5.6.6	[RQ-INTEGRITY-006].....	43
146	5.6.7	[RQ-INTEGRITY-007].....	43
147	5.6.8	[RQ-INTEGRITY-008].....	43
148	5.6.9	[RQ-INTEGRITY-009].....	43
149	5.6.10	[RQ-INTEGRITY-010].....	43
150	5.6.11	[RQ-INTEGRITY-011].....	44
151	5.6.12	[RQ-INTEGRITY-012].....	44
152	5.6.13	[RQ-INTEGRITY-013].....	44
153	5.6.14	[RQ-INTEGRITY-014].....	44
154	5.6.15	[RQ-INTEGRITY-015].....	44
155	5.6.16	[RQ-INTEGRITY-016].....	44
156	5.6.17	[RQ-INTEGRITY-017].....	44
157	5.6.18	[RQ-INTEGRITY-018].....	44
158	5.6.19	[RQ-INTEGRITY-019].....	45
159	5.6.20	[RQ-INTEGRITY-020].....	45
160	5.6.21	[RQ-INTEGRITY-021].....	45
161	5.6.22	[RQ-INTEGRITY-022].....	45
162	5.6.23	[RQ-INTEGRITY-023].....	45
163	5.7	Data Minimization	45
164	5.7.0	Introduction to data minimization requirements	45
165	5.7.1	[RQ-MINIMAL-001].....	46
166	5.7.2	[RQ-MINIMAL-002].....	46
167	5.7.3	[RQ-MINIMAL-003].....	46
168	5.8	Availability and Resilience	46
169	5.8.0	Introduction to availability and resilience requirements	46
170	5.8.1	[RQ-AVAIL-001]	46
171	5.8.2	[RQ-AVAIL-002]	46
172	5.8.3	[RQ-AVAIL-003]	46
173	5.8.4	[RQ-AVAIL-004]	47
174	5.8.5	[RQ-AVAIL-005]	47
175	5.8.6	[RQ-AVAIL-006]	47
176	5.8.7	[RQ-AVAIL-007]	47
177	5.8.8	[RQ-AVAIL-008]	47
178	5.8.9	[RQ-AVAIL-009]	47

179	5.8.10	[RQ-AVAIL-010]	48
180	5.8.11	[RQ-AVAIL-011]	48
181	5.8.12	[RQ-AVAIL-012]	48
182	5.8.13	[RQ-AVAIL-013]	48
183	5.8.14	[RQ-AVAIL-014]	48
184	5.8.15	[RQ-AVAIL-015]	48
185	5.8.16	[RQ-AVAIL-016]	48
186	5.8.17	[RQ-AVAIL-017]	48
187	5.8.18	[RQ-AVAIL-018]	49
188	5.9	Impact Minimization.....	49
189	5.9.0	Introduction to impact minimization requirements	49
190	5.9.1	[RQ-IMPACT-001].....	49
191	5.10	Attack Surface Minimization.....	49
192	5.10.0	Introduction to attack surface minimization	49
193	5.10.1	[RQ-SURFACE-001]	49
194	5.10.2	[RQ-SURFACE-002]	49
195	5.10.3	[RQ-SURFACE-003]	49
196	5.10.4	[RQ-SURFACE-004]	49
197	5.10.5	[RQ-SURFACE-005]	50
198	5.10.6	[RQ-SURFACE-006]	50
199	5.10.7	[RQ-SURFACE-007]	50
200	5.11	Logging and Monitoring.....	50
201	5.11.0	Introduction to logging and monitoring requirements	50
202	5.11.1	[RQ-LOG-001].....	50
203	5.11.2	[RQ-LOG-002].....	50
204	5.11.3	[RQ-LOG-003].....	50
205	5.11.4	[RQ-LOG-004].....	51
206	5.11.5	[RQ-LOG-005].....	51
207	5.12	Vulnerability Management	51
208	5.12.0	Introduction to vulnerability management requirements	51
209	5.12.1	[RQ-VULN-001]	51
210	5.12.2	[RQ-VULN-002]	51
211	5.12.3	[RQ-VULN-003]	52
212	5.12.4	[RQ-VULN-004]	52
213	5.12.5	[RQ-VULN-005]	52
214	5.12.6	[RQ-VULN-006]	52
215	5.12.7	[RQ-VULN-007]	52
216	5.12.8	[RQ-VULN-008]	52
217	5.12.9	[RQ-VULN-009]	52
218	5.13	Security Testing and Review	52
219	6	Conformity assessment and testing	53
220	6.1	General.....	53
221	6.1.1	Assessment principles	53
222	6.1.2	Assessment structure	53
223	6.1.3	Verdicts	53
224	6.1.4	Risk level and assessment depth	53
225	6.1.5	Boot manager assessment considerations.....	54
226	6.1.6	Component vs product assessment.....	54
227	6.1.7	Assessment report requirements.....	54
228	6.2	EA-BM-DESIGN: Secure design.....	55
229	6.2.1	Assessment reference	55
230	6.2.2	Objective	55
231	6.2.3	Pass criteria	55
232	6.2.3.1	Component isolation.....	55
233	6.2.3.2	Key material protection	55
234	6.2.3.3	Handoff security	56
235	6.2.3.4	Attack surface minimization.....	56
236	6.2.3.5	Input validation.....	56
237	6.2.4	Evidence.....	56
238	6.3	EA-BM-DEFAULT: Secure defaults.....	57
239	6.3.1	Assessment reference	57

240	6.3.2	Objective	57
241	6.3.3	Pass criteria	57
242	6.3.3.1	Secure default state.....	57
243	6.3.3.2	Fallback prevention	57
244	6.3.3.3	Secure state restoration	58
245	6.3.3.4	Data minimization	58
246	6.3.4	Evidence.....	58
247	6.4	EA-BM-AUTH: Authentication and access control	59
248	6.4.1	Assessment reference	59
249	6.4.2	Objective	59
250	6.4.3	Pass criteria	59
251	6.4.3.1	Trust anchor modification	59
252	6.4.3.2	Configuration protection.....	59
253	6.4.3.3	Authentication mechanisms.....	60
254	6.4.3.4	Policy indication.....	60
255	6.4.4	Evidence.....	60
256	6.5	EA-BM-CONFID: Confidentiality	60
257	6.5.1	Assessment reference	60
258	6.5.2	Objective	61
259	6.5.3	Pass criteria	61
260	6.5.3.1	Key separation.....	61
261	6.5.3.2	Sensitive data protection.....	61
262	6.5.3.3	Credential storage.....	61
263	6.5.3.4	Network confidentiality.....	61
264	6.5.3.5	Secure disposal	62
265	6.5.4	Evidence.....	62
266	6.6	EA-BM-INTEGRITY: Integrity protection	63
267	6.6.1	Assessment reference	63
268	6.6.2	Objective	63
269	6.6.3	Pass criteria	63
270	6.6.3.1	Chain of trust	63
271	6.6.3.2	Cryptographic mechanisms	64
272	6.6.3.3	Verification integrity	64
273	6.6.3.4	Configuration integrity	64
274	6.6.3.5	Network boot integrity.....	64
275	6.6.3.6	Anti-rollback.....	65
276	6.6.3.7	Trust hierarchy.....	65
277	6.6.3.8	Cryptographic agility	65
278	6.6.4	Evidence.....	65
279	6.7	EA-BM-AVAIL: Availability and resilience.....	66
280	6.7.1	Assessment reference	66
281	6.7.2	Objective	66
282	6.7.3	Pass criteria	66
283	6.7.3.1	Configuration recovery	66
284	6.7.3.2	Redundancy	66
285	6.7.3.3	Resource limits	67
286	6.7.3.4	Security verification integrity	67
287	6.7.3.5	Recovery security	67
288	6.7.3.6	Failure handling.....	67
289	6.7.3.7	Network resilience.....	68
290	6.7.3.8	Temporal validity	68
291	6.7.4	Evidence.....	68
292	6.8	EA-BM-LOG: Logging and measurement	68
293	6.8.1	Assessment reference	68
294	6.8.2	Objective	68
295	6.8.3	Pass criteria	69
296	6.8.3.1	Boot measurement	69
297	6.8.3.2	Attestation support.....	69
298	6.8.3.3	Security event logging	69
299	6.8.4	Evidence.....	69
300	6.9	EA-BM-VULN: Vulnerability handling.....	70
301	6.9.1	Assessment reference	70

302	6.9.2	Objective	70
303	6.9.3	Pass criteria	70
304	6.9.3.1	Version identification (RQ-VULN-001)	70
305	6.9.3.2	Update capability	70
306	6.9.3.3	Defence in depth	71
307	6.9.3.4	Security policy updates	71
308	6.9.3.5	Update verification	71
309	6.9.3.6	Update safety	71
310	6.9.4	Evidence	72
311	Annex A (normative): Relationship between the present document and the essential requirements		
312	of EU Regulation 2024/2847		73
313	Annex B (informative): Risk analysis for threat modeling		75
314	B.1	Purpose and methodology	75
315	B.1.1	General	75
316	B.1.2	Methodology approach	75
317	B.2	Threat identification methodology	76
318	B.2.1	Development approach	76
319	B.2.2	Threat sources	76
320	B.2.3	Categorization rationale	76
321	B.2.4	Limitations	76
322	B.3	Threat catalogue	76
323	B3.0	Introduction	76
324	B.3.1	T-INTEGRITY: Boot integrity attacks	76
325	B.3.1.1	Code execution attacks	76
326	B.3.1.2	Configuration tampering	77
327	B.3.1.3	Cryptographic compromise	77
328	B.3.1.4	Parser and input validation attacks	78
329	B.3.1.5	Rollback attacks	78
330	B.3.2	T-PERSIST: Persistent firmware threats	78
331	B.3.3	T-PHYS: Physical attacks	79
332	B.3.4	T-SUPPLY: Supply chain attacks	80
333	B.3.5	T-NET: Network-based attacks	80
334	B.3.6	T-AVAIL: Availability and resilience threats	80
335	Annex C (informative): Product Documentation		82
336	C.1	Security design documentation	82
337	C.2	Physical security documentation	82
338	C.3	Integrity mechanism documentation	82
339	C.4	Configuration security documentation	82
340	C.5	Vulnerability handling documentation	82
341	C.6	Security testing evidence	83
342	C.7	Documentation format	83
343	Annex D (informative): Vulnerability management considerations		84
344	Annex E (informative): Relation to NIST SP 800-193		85
345	E.1	Purpose	85
346	E.2	Protection (SP 800-193, Section 4.2)	85
347	E.2.1	Authenticated update mechanism (Section 4.2.1.1)	85
348	E.2.2	Integrity protection (Section 4.2.1.2)	85
349	E.2.3	Non-bypassability (Section 4.2.1.3)	86
350	E.3	Detection (SP 800-193 Section 4.3)	86

351	E.3.1	Detection of corrupted code (Section 4.3.1)	86
352	E.3.2	Detection of corrupted critical data (Section 4.3.2)	87
353	E.3.3	Notification	87
354	E.4	Recovery (SP 800-193 Section 4.4)	87
355	E.4.1	Recovery of mutable code (Section 4.4.1)	87
356	E.4.2	Recovery of critical data (Section 4.4.2)	87
357	E.5	Firmware categories	88
358		Annex F (informative): Assessment guidance	89
359	F.1	General	89
360	F.2	Common verification approaches	89
361	F.2.1	Documentation review	89
362	F.2.2	Functional verification	89
363	F.2.3	Resistance testing	89
364	F.3	Equipment considerations	89
365	F.4	Test environment	90
366		History	91
367			
368			

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 [i.3] final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A-1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document is a European harmonised standard that defines technical cybersecurity requirements for boot managers as products with digital elements according to Regulation (EU) 2024/2847 [i.1], the Cyber Resilience Act (CRA).

It addresses boot managers identified in Annex III, Point 8 as important products with digital elements (Class I), in the Annex to Commission Implementing Regulation 2025/2392 [i.2] on the technical description of the categories of important and critical products with digital elements and as specified in standardisation request C(2025) 618 [i.3], line item 23. It complements the vertical and horizontal standards developed under the same mandate including prEN 40000-1-2 [2] and prEN 40000-1-3 [i.4], by providing product-specific requirements for boot managers. Conformance with the normative requirements in Clause 5 provides manufacturers with presumption of conformity to the Essential Cybersecurity Requirements of the CRA for boot manager products. To demonstrate presumption of conformity using the present document, manufacturers:

- a) verify their product is within scope (clause 1);
- b) assess risk factors based on deployment context (clause 4.7.8);
- c) determine the applicable risk level (LOW, MEDIUM, HIGH);
- d) implement requirements matching risk level and product capabilities (clause 5); and
- e) document assessment per clause 6.

1 Scope

1.1 General

The present document specifies technical cybersecurity product requirements for boot managers based on the Essential Cybersecurity Requirements in the Regulation (EU) 2024/2847 (Cyber Resilience Act) [i.1].

The scope covers software and firmware components that manage the boot process from power-on through establishment of the chain of trust to handoff to the boot target.

Requirements apply using a risk-based approach determined by risk factors in clause 4.7.8 and capability-based conditions defined in clause 4.3.3.

1.2 In-scope products

Products in scope include are boot management software and firmware regardless of distribution model or integration level. These are:

- **System firmware** that performs hardware initialization and boot management
- **Bootloaders** that manage boot target selection, verification, and loading
- **Embedded boot firmware** in IoT and embedded devices
- **Network boot implementations** enabling remote boot capabilities
- Boot managers that **integrate with hardware security components** for chain of trust establishment

NOTE 1: Boot managers may be single-stage (direct loading) or multi-stage (staged verification).

NOTE 2: For microcontrollers (MCUs) and microprocessors (MPUs):

- **Silicon-integrated immutable firmware:** Mask ROM, fused code, or boot firmware integrated during chip manufacturing is assessed as part of MCU/MPU hardware under semiconductor standards.
- **Updateable boot managers:** Boot software in flash storage (including OTP programmed post-manufacture) is assessed using the present document when distinctly identifiable or independently updatable.

NOTE 3: Runtime services executing after boot target handoff (such as secure monitor mode handlers or attestation services) are in scope only if they provide verification or attestation services to the boot process itself, not to the boot target.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] [prEN 40000-1-1](#): "Cybersecurity requirements for products with digital elements - Part 1-1: Vocabulary", (produced by CEN).
- [2] [prEN 40000-1-2](#): "Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience Principles for cyber resilience", (produced by CEN)..
- [3] [EUCC Guidelines on Cryptography, Version 2.0, May 2025](#) (European Cybersecurity Certification Group).

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
- [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.
- [i.3] [C\(2025\)618 - Standardisation request M/606](#): Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
- [i.4] prEN 40000-1-3: "Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling", (produced by CEN).
- [i.5] prEN 40000-1-4: "Cybersecurity requirements for products with digital elements - Part 1-4: Generic Security Requirements", (produced by CEN).
- [i.6] TR 40000-1-5: "Cybersecurity requirements for products with digital elements - Part 1-5: Threats and Security Objectives".

496	[i.7]	ETSI EN 304 619: "CYBER; CRA; Cybersecurity requirements for software that searches for, removes, or quarantines malicious software".
498	[i.8]	ETSI EN 304 621: "CYBER; CRA; Cybersecurity requirements for Network Management systems".
500	[i.9]	ETSI EN 304 622: "CYBER; CRA; Cybersecurity requirements for Security information and event management (SIEM) systems".
502	[i.10]	ETSI EN 304 624: "CYBER; CRA; Cybersecurity requirements for Public key infrastructure and digital certificate issuance software".
504	[i.11]	ETSI EN 304 625: "CYBER; CRA; Cybersecurity requirements for physical and virtual network interfaces".
506	[i.12]	ETSI EN 304 626: "CYBER; CRA; Cybersecurity requirements for operating systems".
507	[i.13]	ETSI EN 304 627: "CYBER; CRA; Cybersecurity requirements for routers, modems intended for the connection to the internet, and switches".
509	[i.14]	ETSI EN 304 635: "CYBER; CRA; Cybersecurity requirements for hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments".
512	[i.15]	ETSI EN 304 636: "CYBER; CRA; Cybersecurity requirements for firewalls, intrusion detection and/or prevention systems".
514	[i.16]	ETSI TS 103 928: "Cyber Security (CYBER); Cyber Security for Home Gateways; Conformance Assessment of Security Requirements as vertical from Consumer Internet of Things".
516	[i.17]	EN 17927:2023: "Security Evaluation Standard for IoT Platforms (SESIP)".
517	[i.18]	ISO/IEC 15408: "Common Criteria for Information Technology Security Evaluation".
518	[i.19]	NIST SP 800-193: "Platform Firmware Resiliency Guidelines", National Institute of Standards and Technology.
520	[i.20]	CAPECNon-ASCII character™ / 0x2122: "Common Attack Pattern Enumeration and Classification", MITRE Corporation.
522	[i.21]	MITRE EMB3DNon-ASCII character™ / 0x2122: "Embedded Device Security Threat Model", MITRE Corporation.
524	[i.22]	CWE: "Common Weakness Enumeration", MITRE Corporation.
525	[i.23]	UEFI Specification Version 2.11 (December 2024) UEFI Specification Version 2.11, UEFI Forum.
527	[i.24]	TPM 2.0 Keys for Device Identity and Attestation v1.10, Trusted Computing Group.
528	[i.25]	DICE Layering Architecture Version 1.0, Trusted Computing Group.
529	[i.26]	DICE Attestation Architecture v1.2, Trusted Computing Group.

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [1] and the following apply:

attestation: Process of providing cryptographic evidence about boot state, configuration, and measurements to a local or remote verifier.

- 536 NOTE: Attestation enables trust decisions based on demonstrated boot integrity without necessarily preventing
537 execution of unverified code.
- 538 EXAMPLE: Attestation may include measurement logs, signed attestation statements, and cryptographic proofs of boot
539 component identity
- 540 **boot component:** any executable code, firmware module, configuration data, or cryptographic material loaded and used
541 during the boot process
- 542 **boot device:** any storage medium or interface from which boot code can be loaded and executed, including internal
543 storage, removable media, or network sources.
- 544 **boot managers:** Software or firmware component that controls the boot process and allows management of multiple
545 boot targets or boot configurations after power-on or reset.
- 546 NOTE: This term includes both single-purpose bootloaders and multi-function firmware with boot management
547 capabilities.
- 548 **boot sequence:** ordered series of operations from power-on through hardware initialization, boot manager execution,
549 and handoff to the boot target
- 550 **boot source:** Logical origin from which boot code can be loaded and executed.
- 551 EXAMPLE: boot devices, network interfaces, and debug interfaces.
- 552 NOTE: Each source presents different security boundaries and threat exposures.
- 553 **boot target:** software component to which the boot manager transfers control upon successful completion of its
554 designated function, such as an operating system kernel, hypervisor, another bootloader, or an embedded application
- 555 **chain of trust:** sequential verification where each boot component validates the next, also known as transitive trust or
556 trust chain, establishing security from hardware root to the boot target
- 557 **certificate:** A data structure that associates a public key with an identity, optionally including usage constraints, validity
558 period, and other attributes.
- 559 NOTE: A certificate may be signed by a certification authority or may be self-signed. In the context of the present
560 document, "certificate" refers to both ITU-T X.509-compliant certificates and minimal public key
561 serializations, as specified in the relevant requirements..
- 562 **critical data:** data whose corruption would prevent successful boot completion or compromise security verification,
563 including boot code, verification keys, anti-rollback counters, and security policy settings
- 564 **defence-in-depth:** security strategy employing multiple, overlapping, and diverse protection mechanisms so that
565 compromise of any single mechanism does not result in complete security failure.
- 566 NOTE: In the present document, "threat" is used synonymously with "cyber threat" as defined in Regulation (EU)
567 2024/2847 [i.1].
- 568 **enforcement:** active prevention of unauthorized actions through cryptographic verification and blocking of execution
569 when verification fails, as distinct from detection-only approaches that record but do not prevent execution
- 570 **essential operation:** operation required for the boot manager to complete its primary function of loading and
571 transferring control to a boot target
- 572 **evaluation activity:** assessment procedure addressing a group of related requirements
- 573 **firmware:** low-level software stored in non-volatile memory on the device/product that provides hardware initialization
574 and runtime services, including boot managers
- 575 **firmware runtime services:** functions provided by boot manager firmware that remain accessible to the operating
576 system after boot handoff, typically including variable storage, time services, and system management functions
- 577 **immutable component:** component whose code cannot be modified after manufacture or initial programming,
578 typically implemented in ROM (Read-Only Memory), OTP (One-Time Programmable) storage, e-fuses, or
579 write-protected flash memory

- 580 **handoff:** transfer of execution control from the boot manager to the boot target, marking the completion of the boot
581 manager's function and the beginning of boot target execution
- 582 **hardware security component:** generic term for hardware-based security modules that provide cryptographic services,
583 secure storage, or isolated execution environments
- 584 NOTE: TPM and HSM are examples of hardware security components. The generic term 'hardware security
585 component' is used throughout the present document unless referring to specific implementation
586 examples.
- 587 **measured boot:** recording cryptographic measurements of boot components before execution for attestation without
588 blocking execution
- 589 **monotonic counter:** counter value that can only increase, never decrease, used for anti-rollback protection to make
590 version downgrade detectable
- 591 **network boot:** loading boot components from network sources using protocols such as PXE or HTTPS Boot
- 592 **physical presence:** Requirement for a user to be physically at the device location with direct physical access to the
593 device to perform certain security-sensitive operations, typically verified through local keyboard input or button presses
- 594 NOTE: Physical presence can also encompass operations conducted in a controlled environment such as a
595 manufacturing plant..
- 596 **recovery boot:** specialized boot process designed to restore system functionality after failures
- 597 **rollback protection:** security mechanism preventing unauthorized installation of older firmware versions that may
598 contain known vulnerabilities
- 599 **Root of Trust:** Component providing foundational trust for the system through hardware-protected execution and
600 storage
- 601 NOTE: Root of Trust is typically implemented in immutable ROM, hardware security modules, or physically
602 isolated processors. Serves as the anchor for chain of trust verification.
- 603 **secure boot:** specific UEFI implementation of verified boot as defined in the UEFI Specification
- 604 **security-critical configuration:** configuration settings whose modification would reduce security posture, including
605 verification enable/disable settings, trust anchor databases, certificates, user-enrolled keys, boot order, and recovery
606 mode settings
- 607 **sensitive data:** Data requiring protection from disclosure
- 608 EXAMPLE: Sensitive data include cryptographic private keys and symmetric keys.
- 609 NOTE: . Unauthorized access to sensitive data enables impersonation, forgery, or decryption of protected
610 content..
- 611 **trust anchor:** public key, certificate, or cryptographic hash that serves as the starting point for verification and is
612 trusted without requiring further validation
- 613 **update capability:** ability to modify boot manager code, configuration, or security policies after initial deployment,
614 ranging from configuration-only updates to full firmware replacement
- 615 **verified boot:** cryptographic verification of boot components before execution to ensure only authorized code runs
616 during system initialization
- 617 NOTE: . Implementations verify authenticity using cryptographic signatures or authenticated hashes bound to
618 cryptographic keys or hardware roots of trust

619 3.2 Symbols

620 Void.

621 3.3 Abbreviations

622 For the purposes of the present document, the abbreviations given in prEN 40000-1-1 [1] and the following apply

623	BIOS	Basic Input/Output System
624	CDI	Compound Device Identity
625	CRC	Cyclic Redundancy Check
626	DICE	Device Identifier Composition Engine
627	DMA	Direct Memory Access
628	HSM	Hardware Security Module
629	MAC	Message Authentication Code
630	NVRAM	Non-Volatile Random Access Memory
631	OS	Operating System
632	OTP	One-Time Programmable
633	PCR	Platform Configuration Register
634	PXE	Preboot Execution Environment
635	ROM	Read-Only Memory
636	SBOM	Software Bill of Materials
637	TEE	Trusted Execution Environment
638	TOCTOU	Time-Of-Check-Time-Of-Use
639	TPM	Trusted Platform Module
640	UEFI	Unified Extensible Firmware Interface

641 4 Product description

642 4.1 Intended purpose and reasonably foreseeable use

643 4.1.1 Intended purpose

644 Boot managers establish initial system trust and manage the boot process from power-on through handoff to the boot
 645 target. They serve as the foundational trust component that executes before operating systems or security services are
 646 available.

647 The intended purpose includes:

- 648 • Establishing the initial chain of trust for the system.
- 649 • Loading and transferring control to boot targets (such as another bootloader, operating systems, hypervisors, or
 650 embedded applications).
- 651 • Managing boot configuration and security policy.

652 Where capable it also includes:

- 653 • Verifying integrity of boot components.
- 654 • Authentication of boot components.
- 655 • Recording measurements for attestation.
- 656 • Providing recovery mechanisms.

657 4.1.2 Reasonably foreseeable use

658 Boot managers are components that may be:

- 659 • Integrated into diverse hardware platforms across all industry verticals.
- 660 • Deployed in security contexts ranging from consumer devices to critical infrastructure.

- 661 • Configured by users with varying levels of technical expertise.
- 662 • Operated in environments ranging from physically secure to hostile and untrusted.
- 663 • Transferred to secondary markets without factory reset.
- 664 • Operated beyond the manufacturer's active support lifecycle.
- 665 • Combined with other components in composite products.
- 666 • Subjected to configuration changes by downstream integrators.
- 667 • Used in safety-critical systems where availability requirements may conflict with security update procedures.

668 These reasonably foreseeable uses inform the requirements in clause 5 and the risk analysis methodology in Annex B.

669 Reasonably foreseeable deployment contexts determine risk level determination per clause 4.7.8. Boot managers are
 670 commonly composed of components from multiple sources including silicon vendors, independent BIOS vendors,
 671 OEMs, and open-source projects. Each component may have distinct update mechanisms, vulnerability response
 672 capabilities, and maintenance lifecycles.

673 4.1.3 Reasonably foreseeable misuse

674 Reasonably foreseeable misuse includes use of the boot manager in ways not intended but predictable from human
 675 behaviour or system interactions. Examples include:

- 676 • Disabling security features for convenience
- 677 • Using development/debug modes in production
- 678 • Operating without applying available security updates
- 679 • Connecting to untrusted networks or storage

680 Requirements in Clause 5 address these scenarios through secure defaults and fail-safe behaviour.

681 4.2 Product functions

682 Boot managers establish system trust and load the boot target. This process includes verifying or measuring boot
 683 components, managing boot configuration, and transferring execution control to the selected target.

684 Security functions vary by design. Verified boot implementations block execution of unverified code through
 685 cryptographic signature verification. Measured boot implementations record cryptographic measurements of boot
 686 components for attestation purposes. Both approaches protect boot configuration from unauthorized modification and
 687 may include rollback protection against version downgrade attacks.

688 Configuration capabilities determine how boot behaviour can be modified. Some implementations have fixed behaviour
 689 determined at manufacturing. Others allow modification of security policies during subsequent boots, cryptographic
 690 credentials, and boot target selection. Boot managers with configuration capability require access controls to prevent
 691 unauthorized changes.

692 Lifecycle management includes update, recovery, and reset functions. Updates modify boot manager firmware or
 693 configuration post-deployment. Recovery functions provide alternative boot paths when primary operations fail. Reset
 694 capabilities support secure decommissioning by erasing cryptographic material and restoring default configurations,
 695 where technically feasible. However, when cryptographic material or configuration data are stored in immutable
 696 components such as e-fuses or ROM, complete erasure or restoration may not be possible.

697 4.3 Architecture

698 4.3.1 Boot architecture

699 4.3.1.1 Unverified boot

700 Unverified Boot implements sequential stage execution without cryptographic verification mechanisms.

701 The system begins with power-on, proceeds through hardware initialization, and continues with sequential stage
702 execution where each stage directly loads and executes the next until the boot target is reached.

703 Unverified boot implements no cryptographic authentication mechanisms, but includes simple integrity checks such as
704 CRC, checksums or hashes. These mechanisms may detect accidental corruption but do not provide protection against
705 deliberate modification or substitution attacks.

706 Unverified boot is appropriate for environments where physical security controls provide the primary protection, or for
707 device categories (e.g. sensors) where risk assessment determines that the assets stored or transmitted do not warrant
708 verified boot implementation.

```
709 Power On -> Hardware Init -> Boot Manager -> Boot Target
710           |               |               |
711           [ROM/Flash]     [Configuration] [Handoff]
712
```

713 4.3.1.2 Verified boot

714 Verified boot implements cryptographic verification with enforcement throughout the boot process. Components are
715 cryptographically verified before execution, creating a verification chain from power-on through boot target execution.

716 Components are verified against stored cryptographic signatures or authenticated hash values and if verification fails the
717 system halts the boot process and potentially triggers recovery mode. Initial verification material (keys or hashes) may
718 be stored in hardware-protected memory, fuses, or one-time programmable storage. Systems implementing verified
719 boot require cryptographic verification capabilities and secure storage for verification material. Verified boot employs
720 cryptographic authentication mechanisms using either:

- 721 • Asymmetric cryptography: Digital signatures verified using public keys stored in the trust root (e.g. RSA,
722 ECDSA, EdDSA signatures)
- 723 • Symmetric cryptography: Message Authentication Codes (MACs) or authenticated encryption verified against
724 pre-shared secrets (e.g. HMAC, CMAC, AES-GCM)
- 725 • One-way functions, such as cryptographic hash functions, which are a necessary component in signature
726 systems, and map data and public keys to protected trust anchors

727 NOTE: See [EUCC Guidelines on Cryptography, Version 2.0, May 2025](#) (European Cybersecurity Certification
728 Group). [3] for approved cryptographic mechanisms and depreciation schedules.

729 Both approaches provide cryptographic assurance that boot components have not been modified and originate from a
730 trusted source. When verification fails, the system halts execution and may transition to a degraded secure state, trigger
731 recovery mode, or perform a power reset to prevent execution of unauthorized code.

732 The choice between asymmetric and symmetric authentication (e.g. authenticated hashes), and hash-based verification
733 depends on the threat model, key management capabilities, available cryptographic hardware support, and performance
734 requirements. Non-ASCII character — / 0x2014 particularly in safety-critical contexts where boot time is constrained.

```
735 Power On -> Hardware Init -> Boot Manager -> Boot Target
736           |               |               |               |
737           [Trust Root]   [Verify]         [Verify]         [Handoff]
738           |               |               |               |
739           [Keys/Hashes]----|-----|-----|
740
```

741 4.3.1.3 Measured boot

742 Measured boot records cryptographic measurements of each boot stage without preventing execution. During
743 initialization, the system activates measurement capabilities and records a cryptographic hash of each subsequent stage
744 into secure storage.

745 Each stage computes a cryptographic hash of the next component and stores or extends it into designated registers, and
746 the boot process continues regardless of measurement values. The resulting measurement log provides an attestable
747 record of the boot sequence that can be verified against known-good values or reference measurements.

748 This architecture requires hardware or firmware capable of secure measurement storage and reporting. The fundamental
749 difference from verified boot is in the enforcement policy. The system records measurements in the log but continues
750 the boot process regardless of values. This allows:

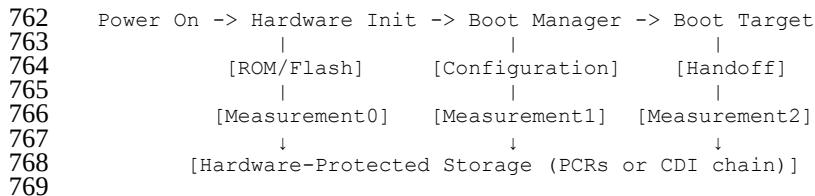
- 751 • Attestation of the actual boot state to remote verifiers.
- 752 • Post-boot analysis and remediation decisions.
- 753 • Operation in degraded mode with logged anomalies.
- 754 • Flexibility for development and recovery scenarios.

755 The measurement log provides a cryptographically protected, auditable record that can be verified locally or remotely
756 against known-good reference values or security policies.

757 Measured boot employs the same cryptographic authentication mechanisms as verified boot.

758 **EXAMPLE:** The diagram below illustrates the general measured boot architecture.

759 Each boot stage computes a cryptographic hash and records it into hardware-protected storage (hardware-based Root of
760 Trust), which may be implemented using a variety of technologies including PCRs in a TPM, CDI derivation in DICE,
761 or other secure measurement storage mechanisms.



770 4.3.2 Functional extensions

771 Boot managers may provide additional functions beyond core boot architecture. Network boot, multi-boot menus, and
772 recovery modes can be combined with unverified, verified, or measured boot architectures. These extensions add
773 functionality but also increase attack surface.

774 4.3.3 Product capabilities

775 4.3.3.0 Introduction

776 Boot manager products have technical capabilities that describe their functional scope and potential attack surface.
777 These capabilities determine which requirements apply and inform threat exposure assessment per clause 4.7.

778 4.3.3.1 Update capability

779 Update capability describes whether and how the boot manager can be modified after initial deployment.

- 780 • **No updates:** Boot manager code and configuration cannot be modified after manufacture.
- 781 • **Configuration updates:** Only boot configuration, security policies, and trusted keys can be updated. Boot
782 manager code remains immutable.

- **Partial updates:** Specific components can be updated while core components remain immutable. Root of trust and initial boot stages cannot be modified.
- **Full updates:** Complete boot manager firmware can be updated including all boot stages.
- **Runtime updates:** Boot manager can be updated while system is running without requiring reboot until next boot cycle.
- **Recovery-mode updates:** Updates can only be applied through a separate recovery mode or alternate boot path.
- **Network updates:** Boot manager can fetch and apply updates directly from network sources.
- **Enclave-managed updates:** Updates are managed by a separate security processor or trusted execution environment.

Products may combine multiple update capabilities (e.g. configuration updates via network, full updates via recovery mode), except products with no update capability.

4.3.3.2 Boot source

Boot source identifies media types from which the boot manager can load and execute code.

- **Internal storage:** Boot exclusively from non-volatile storage integrated within the same package or die as the processor.
- **Fixed storage:** Boot exclusively from non-removable storage physically attached to the system but in a separate package.
- **Removable storage:** Can boot from removable storage devices such as USB, SD cards, or optical media.
- **Network boot:** Can boot from network sources including PXE, HTTP, iSCSI, or cloud services.
- **External expansion:** Can boot from external expansion buses such as Thunderbolt or ExpressCard.
- **Debug interfaces:** Can boot or load code via debug or programming interfaces such as JTAG, SWD, or UART.

Multiple boot sources are common. Each additional source increases attack surface.

NOTE: Requirements referencing "network boot" apply when the boot manager includes Network boot capability. Requirements referencing "network update" apply when the boot manager includes Network updates under update capability. These may overlap but are distinct: network boot loads the entire boot image from network while network update modifies persistent boot manager components.

4.3.3.3 Configuration management

Configuration capability describes whether boot behaviour can be modified through settings.

- **No configuration:** Fixed behaviour with no configurable settings, or configuration set once via one-time programmable mechanisms.
- **Static configuration:** Configuration can be set but requires physical access or special tools to modify.
- **Local configuration:** Configuration modifiable through local interfaces requiring physical presence.
- **Protected configuration:** Configuration modifiable with authentication but without physical presence requirement.
- **Remote configuration:** Configuration modifiable through network interfaces.
- **Runtime configuration:** Configuration modifiable by the operating system through runtime services.

821 4.3.3.4 Hardware security

822 Hardware security describes whether the boot manager utilizes dedicated security hardware.

823 **Software only:** Boot manager operates entirely in software without dedicated security hardware.

824 **Hardware storage:** Utilizes hardware components for protected key storage and cryptographic operations.

825 **Hardware enforcement:** Hardware actively enforces security policies during boot.

826 Hardware enforcement typically includes hardware storage.

827 4.3.3.5 Recovery capability

828 Recovery capability describes how the system can recover from boot failures, corruption, or attacks.

- 829 • **No recovery:** No separate recovery path or fallback boot mechanism.
- 830 • **Basic recovery:** Simple recovery mode or fallback boot option such as safe mode or previous known-good
831 configuration.
- 832 • **Full recovery:** Comprehensive recovery environment with diagnostics, repair tools, and restore capabilities.

833 Recovery mechanisms provide resilience but introduce additional attack surface.

834 4.3.3.6 Logging capability

835 Logging capability describes whether and how the boot manager can record, store, and communicate security-relevant
836 events and operational states during the boot process. The presence, type, and durability of logging functions depend on
837 the boot manager's architecture, resource constraints, and deployment context.

- 838 • **No logging:** The boot manager does not implement any logging functionality. No events or states are recorded
839 during boot in persistent storage.

840 NOTE 1: This variant is typical for resource-constrained devices or early boot stages where logging infrastructure
841 is not available.

- 842 • **Volatile logging:** The boot manager records events in volatile memory during boot. Logs are lost upon power
843 cycle or reset and are accessible only during the current boot session.

844 NOTE 2: Requirements referring to persistent log retrieval cannot be fulfilled when only volatile logging is
845 implemented.

- 846 • **Persistent logging:** The boot manager records events in persistent storage (e.g. flash, NVRAM, dedicated log
847 partition). Logs survive power cycles and can be accessed after reboot.
- 848 • **Hardware-protected logging:** The boot manager utilizes hardware security components (e.g. TPM, secure
849 element, write-once memory) to protect log integrity and prevent tampering.
- 850 • **External logging:** The boot manager exports log events to external interfaces (e.g. serial console, debug ports)
851 for real-time monitoring or remote analysis.

852 Logging capability enables security monitoring and forensic analysis but requires storage resources.

853 4.3.3.7 Authentication capability

854 Authentication capability describes whether the boot manager requires identity verification for privileged operations.

- 855 • **No authentication:** No identity verification for any operations.
- 856 • **Physical presence:** Operations require physical presence detection (button press, jumper) but no credential
857 verification.
- 858 • **Password authentication:** Operations require password or PIN verification.

- **Cryptographic authentication:** Operations require cryptographic credential verification (smart card, certificate, hardware token).

- **Multi-factor authentication:** Operations require multiple authentication mechanisms.

Authentication capability protects configuration and security policy changes from unauthorized modification.

4.3.3.8 Debug interface

Debug interface describes whether the boot manager exposes diagnostic or programming interfaces.

- **No debug interface:** No debug, diagnostic, or programming interfaces present in production.
- **Disabled debug:** Debug interfaces physically present but permanently disabled or fused off.
- **Authenticated debug:** Debug interfaces require authentication before activation.
- **Conditional debug:** Debug interfaces available only in specific modes (e.g. manufacturing, recovery).
- **Open debug:** Debug interfaces accessible without restriction.

Debug interfaces enable development and diagnostics but significantly increase attack surface when accessible.

4.3.4 Resource constraints

Boot managers operate under inherent resource limitations determined by their implementation and hardware platform:

- **Storage:** Restricted firmware storage capacity shared with other components.
- **Computation:** No OS services, drivers, or shared libraries during early stages.
- **Time:** Boot performance requirements limiting security operations.
- **Memory:** Limited RAM available during early boot stages.

Resource constraints influence implementation choices and inform requirement applicability.

4.4 Operational environment

4.4.1 Introduction

The operational environment describes deployment context affecting risk factor assessment per clause 4.7.8. Environmental characteristics are independent of product characteristics and describe where and how the boot manager is deployed.

4.4.2 Physical security context

- **Secure:** Physically secure locations (data centres, secure facilities).
- **Controlled:** Controlled access environments (offices, industrial sites).
- **Restricted:** Limited public access with some monitoring (hospitals, retail).
- **Public:** Publicly accessible with minimal security (kiosks, ATMs, digital signage).
- **Hostile:** Uncontrolled, adversarial environments (consumer devices, field deployment).
- **Mobile:** Travels through varying physical environments (laptops, smartphones, tablets - should assume hostile).

Deployment physical security informs RF-PHYS scoring.

892 4.4.3 Network exposure

893 Boot managers may be deployed with varying levels of network exposure:

- 894 • **None (air-gapped):** No network connectivity.
- 895 • **Isolated:** Private/isolated networks (LAN, industrial networks).
- 896 • **Managed:** Internet-connected within managed environment (VPN, enterprise).
- 897 • **Internet:** Direct internet exposure.
- 898 • **Cellular:** Mobile/cellular networks.

899 Network exposure informs RF-NET scoring.

900 4.4.4 Data sensitivity and value

901 The sensitivity and value of data accessible through or protected by the boot manager affects attacker motivation and
902 consequence severity:

- 903 • **Minimal:** No significant sensitive data (basic sensors, simple IoT).
- 904 • **Personal:** Personal user data (consumer devices, personal files).
- 905 • **Financial:** Financial/payment data (payment terminals).
- 906 • **Health:** Protected health information (medical devices, health records).
- 907 • **Business:** Business confidential data (enterprise systems, intellectual property).
- 908 • **Critical:** Critical infrastructure control (power grid, water systems).
- 909 • **Classified:** Government classified information.

910 Data sensitivity informs RF-DATA scoring.

911 4.4.5 System criticality

912 Impact severity if the boot manager is compromised, considering availability, integrity, and safety:

- 913 • **Non-critical:** Low business impact, non-critical functions, general purpose devices.
- 914 • **Business impact:** Moderate business impact, internal systems, productivity loss, reputation damage.
- 915 • **Safety-critical:** Systems where compromise causes physical harm, critical infrastructure disruption, major
916 financial loss or widespread service disruption.

917 System criticality informs RF-SAFE scoring.

918 4.4.6 Lifecycle expectations

- 919 • **Short:** < 5 years.
- 920 • **Medium:** 5 to 15 years.
- 921 • **Long:** > 15 years.

922 Lifecycle expectations inform RF-PATCH scoring.

923 4.4.7 Administrative control

924 The model for managing configuration and updates:

- 925 • **Centrally managed:** IT department or security operations centre controls all configuration and updates,
926 security policies centrally enforced, compliance monitoring in place.
 - 927 • **User managed:** Individual end-users control configuration and updates. Varying security expertise,
928 inconsistent update adoption.
 - 929 • **Vendor managed:** Manufacturer retains control over updates and configuration. User cannot modify boot
930 security settings.
 - 931 • **Hybrid managed:** Shared responsibility between multiple parties, requires clear responsibility documentation.
 - 932 • **Autonomous:** No administrative interface, device operates independently. Updates require physical access or
933 hardware replacement.
- 934 Administrative control informs RF-PATCH scoring.

935 4.4.8 Availability requirements

- 936 • **Flexible:** Downtime acceptable for updates/maintenance.
- 937 • **Standard:** Normal business availability expectations.
- 938 • **High:** High uptime required.
- 939 • **Critical:** Continuous operation required for safety or critical infrastructure.

940 Availability requirements inform RF-SAFE scoring.

941 4.4.9 Additional environmental characteristics

942 4.4.9.1 Power supply

- 943 • **Mains:** Continuous mains power.
- 944 • **Battery:** Battery-powered.
- 945 • **Energy-harvest:** Energy harvesting (solar, etc.).
- 946 • **UPS:** Mains with UPS backup.

947 4.4.9.2 Environmental stress

948 Harsh environmental conditions affect boot manager reliability and security:

- 949 • **Temperature extremes:** Harsh thermal environments affecting non-volatile memory reliability and boot
950 component integrity.
- 951 • **Vibration and shock:** Mechanical stress causing storage connection failures and data corruption risks.
- 952 • **Radiation:** Environments with ionizing radiation causing storage bit flips requiring error correction and
953 redundancy.
- 954 • **Humidity and corrosion:** Outdoor deployment, marine environments affecting hardware integrity.
- 955 • **Aging effects:** Flash wear (limited write cycles), bit rot, electromigration degradation over extended lifecycles.

956 These stresses increase probability of boot failures, requiring enhanced error detection, redundant storage, and robust
957 recovery mechanisms.

958 4.4.9.3 Update frequency expectations

959 Boot manager update patterns vary by deployment:

- **Never:** ROM-based, OTP firmware, no post-manufacture updates possible.
- **Rare:** Major version updates only (e.g. every 2 to 5 years) for long-lifecycle industrial equipment.
- **Periodic:** Scheduled maintenance windows (quarterly, annually) for enterprise/infrastructure.
- **Responsive:** Updates deployed when vulnerabilities discovered, testing-dependent timeline.
- **Continuous:** Rapid update capability for internet-connected consumer devices.

Update frequency affects vulnerability exposure window and influences defence-in-depth requirements.

4.4.9.4 Interfaces

Boot managers interact through various technical interfaces:

- **Storage:** SPI flash, USB, eMMC, NVMe, SATA with different protection mechanisms.
- **Network:** Ethernet, WiFi supporting PXE, HTTP Boot, iSCSI protocols.
- **Debug:** JTAG, SWD, UART, USB, SPI programmers requiring access control.
- **User:** Serial console, display output, keyboard, remote management (IPMI/BMC).
- **Hardware:** Hardware security component connections (SPI/I2C or other protocols).
- **Runtime:** Firmware runtime services, ACPI tables, SMM/SMI interfaces.

Boot managers receive inputs such as hardware reset signals, configuration data, boot media, network packets, or user input, and produce outputs including system state, measurement logs, or error codes. Control interfaces include configuration utilities, update mechanisms, recovery modes, and remote management protocols.

4.5 Distribution of security functions

4.5.1 Introduction

As a component within a larger system, boot managers both provide and depend upon security functions. This clause clarifies the security boundaries and responsibilities.

4.5.2 Security functions provided by the boot manager

Depending on capabilities, boot managers provide:

- Initial trust establishment before any other software executes.
- Boot chain integrity verification.
- Cryptographic measurement recording for attestation.
- Secure handoff to boot target.
- Protection of boot configuration and policy.
- Rollback protection for boot components.
- Root of trust for measurement.
- Root of trust for verification.

NOTE: Verification, measurement, and rollback capabilities are implementation dependent.

992 4.5.3 Security functions required from the platform

993 The boot manager depends on the following security functions from the hardware platform:

- 994 • Hardware root of trust (immutable boot ROM or equivalent)
- 995 • Secure storage for cryptographic keys and configuration
- 996 • Protected execution environment (where available)
- 997 • Hardware security components for key storage (where available)
- 998 • Physical security mechanisms (where available)
- 999 • Secure manufacturing and provisioning

1000 NOTE: Hardware security mechanisms may include various implementations such as TPM, HSM, secure
 1001 elements, or write protection mechanisms that prevent tampering of boot manager code by the operating
 1002 system or other software executing after boot handoff.

1003 4.5.4 Security functions delegated to boot target

1004 The following security functions are outside the scope of the boot manager and are the responsibility of the loaded boot
 1005 target:

- 1006 • Runtime security monitoring and threat detection
- 1007 • User authentication and authorization (post-boot)
- 1008 • Network security and firewall functions
- 1009 • Application security and sandboxing
- 1010 • Ongoing vulnerability management and patching
- 1011 • Security event logging (post-handoff)

1012 NOTE: Some boot managers provide runtime services that remain accessible after boot target handoff (e.g. UEFI
 1013 runtime services for variable storage, time services, or capsule updates). These runtime services are
 1014 within scope when they affect boot security, integrity, or configuration.

1015 4.5.5 Trust boundaries

1016 Boot managers operate across multiple trust boundaries where different security domains interface.

1017 Boot managers interface with multiple trust domains, each requiring different verification approaches, for example root
 1018 of trust by hardware vendor, security hashes for different stages by firmware or board OEM, or certificates by operating
 1019 system vendors.

- 1020 • **Hardware:** Components the boot manager trusts without verification capability, including CPU microcode,
 1021 platform security processors providing opaque services, immutable boot ROM and/or e-fuses.
- 1022 • **Storage:** Components requiring verification before use, including all data read from storage media,
 1023 configuration data, and boot components that may have been tampered with or corrupted.
- 1024 • **Network:** Untrusted input requiring complete verification, including all network-sourced boot components,
 1025 protocol data, and remote configuration.
- 1026 • **Operating system:** Components to which the boot manager transfers control, including operating systems,
 1027 hypervisors, and runtime services. This boundary is bidirectional when the operating system performs updates
 1028 to the boot manager.

1029 These boundaries define where boot managers can enforce security properties versus where they must rely on trust
 1030 assumptions or external security mechanisms.

1031 4.5.6 Relation to other vertical CRA standards

1032 Boot managers provide or receive security foundations for:

- 1033 • **Antivirus** (ETSI EN 304 619 [i.7]): Early-launch anti-malware, driver signing.
- 1034 • **NMS** (ETSI EN 304 621 [i.8]): Attestation reports, boot events for monitoring.
- 1035 • **SIEM** (ETSI EN 304 622 [i.9]): Boot security events.
- 1036 • **PKI** (ETSI EN 304 624 [i.10]): Certificate validation for verified boot; also provides certificate chains to boot
1037 managers.
- 1038 • **Network interfaces** (ETSI EN 304 625 [i.11]): Secure network boot transport.
- 1039 • **Operating systems** (ETSI EN 304 626 [i.12]): Verified boot chain, secure handoff.
- 1040 • **Routers** (ETSI EN 304 627 [i.13]): Embedded boot verification.
- 1041 • **Hypervisors** (ETSI EN 304 635 [i.14]): Root of trust for virtual firmware.
- 1042 • **Firewalls** (ETSI EN 304 636 [i.15]): Boot integrity for network appliances.

1043 4.6 Users

1044 4.6.1 Introduction

1045 Boot managers operate mostly without any user interaction during normal operation, with security decisions
1046 predetermined by configuration rather than runtime user input.

1047 4.6.2 User categories

1048 Boot managers interact with different user types across their lifecycle:

- 1049 • Manufacturers: during production and initial provisioning.
- 1050 • System integrators: during deployment.
- 1051 • System administrators: for enterprise configuration.
- 1052 • End users: for boot selection.
- 1053 • Service technicians: during maintenance.

1054 4.6.3 User interaction patterns

- 1055 • Manufacturing phase: Fuse programming, key provisioning, initial firmware installation, testing.
- 1056 • Configuration phase: Use of setup and configuration tools > NOTE: In some business models, operations such
1057 as fuse programming or key provisioning may be deferred from the manufacturing phase to the configuration
1058 phase, allowing OEMs to customize or finalize device configuration post-manufacture.
- 1059 • Boot phase: Physical presence detection, boot target selection, recovery mode activation.
- 1060 • Maintenance phase: Updates, rollbacks, resets.
- 1061 • Decommissioning phase: Secure erasure, key destruction, decommissioning verification.

1062 These interactions represent points where boot manager security can be modified, compromised or bypassed, requiring
1063 appropriate access controls and authentication mechanisms.

1064 Interactions requiring special attention:

- 1065 • Device resale or transfer.
- 1066 • Return for service/warranty.
- 1067 • Employee termination (enterprise devices).
- 1068 • End-of-life disposal.

1069 These scenarios present opportunities for security policy changes, credential transfer, or secure erasure failures that
1070 could compromise subsequent users or violate data protection obligations.

1071 User interactions requiring authentication are addressed in clause 5.4. Physical presence verification provides protection
1072 for security-critical configuration changes.

1073 4.7 Risks, threats and security context

1074 4.7.1 General

1075 Boot managers present unique risks due to their privileged position, persistence, invisibility, and role as trust
1076 foundation:

- 1077 • Privileged position: Operates at highest privilege level with direct hardware access.
- 1078 • Persistence: Survives OS reinstall and traditional security remediation.
- 1079 • Invisibility: Executes below OS visibility and security tools.
- 1080 • Trust establishment: Forms the foundation for all subsequent security decisions

1081 These characteristics mean boot manager compromises have disproportionate impact compared to application or
1082 OS-level compromises. Different capabilities introduce different threat exposures.

1083 Manufacturers identify cybersecurity risks based on intended purpose, reasonably foreseeable use, and conditions of use
1084 per CRA Article 10. Requirements are proportionate to the identified risk level. For boot managers, risks are assessed
1085 against Confidentiality, Integrity, and Availability, along with impact on other devices and attacker persistence. The use
1086 cases illustrate how intended purpose, reasonably foreseeable use, and reasonably foreseeable misuse influence risk
1087 assessment. Each use case reflects deployment contexts where the boot manager's security properties affect product
1088 compliance with CRA requirements.

1089 4.7.2 Confidentiality

1090 The confidential information that the bootloader may have access to include the storage encryption keys, network
1091 access keys, and the user or device identity. This information may be stored in non-volatile storage, in a trusted
1092 hardware element, or retrieved from another system as part of a remote attestation.

1093 If this data is stored in clear text in non-volatile storage, a local attacker may be able to gain access to the confidential
1094 information. This sort of storage is only suggested for use cases where physical access is protected by other means.

1095 Even if the confidential data is stored in a trusted hardware component, the local bus that connects the bootloader to the
1096 external hardware may be compromised by a local attacker. In some cases, the secrets are returned to the bootloader in
1097 plain text on the bus, putting them at risk of disclosure.

1098 If the secrets are encrypted on the bus, but the measurements from the bootloader to the trusted hardware component are
1099 not, the device may be susceptible to a replay attack leading to disclosure of the secrets.

1100 If the devices on the local bus are not authenticated in some way, a local attacker might be able to install an interposer
1101 to intercept the measurements and modify them, similar to the replay attack, to reveal the secrets.

1102 If the attacker can downgrade from verified to measured boot, they should not be able to unseal confidential data since
1103 the configuration measurements will not match, but they might be able to present an authentic looking authentication
1104 screen to the user and trick them into revealing recovery or other secrets.

1105 During a remote attestation, an attacker may be able to force a protocol downgrade that could lead to a disclosure of
1106 user identity or the returned secrets.

1107 A loss of confidentiality of disk encryption keys could lead to a larger loss of confidentiality of the disk contents, as
1108 well as could be leveraged to a persistent loss of integrity in the operating system.

1109 4.7.3 Integrity

1110 Integrity for the bootloader means that the OS that it hands control to is the one that the system's owner intends, that the
1111 system is configured as intended, and any hardware measurements correctly reflect this configuration. Any attack that
1112 compromises integrity can also compromise availability and confidentiality, and potentially compromise the
1113 availability, confidentiality and integrity of the operating system that it loads.

1114 An attacker that can modify the bootloader configuration can lead to a loss of integrity, such as by changing the
1115 verification keys to load an attacker signed operating system or enabling a debug mode that does not perform validation.

1116 An attacker that can force the bootloader to execute untrusted code, through misconfiguration or other means such as
1117 TOCTOU, can lead to a loss of integrity.

1118 An attacker might be able to modify measurements when they are being sent to the trusted hardware element, leading to
1119 a failure of integrity of the measurements, which could lead to faked attestations.

1120 An attacker might rollback the system configuration to an older, vulnerable but still signed version that could be
1121 exploited to compromise integrity unless there are rollback protections.

1122 Additionally, some attacks on bootloader integrity can lead to persistence in flash, disk, or other storage, allowing the
1123 attacker to compromise the integrity of not only the current boot, but all future boots as well.

1124 Attacks on bootloader runtime services from the operating system or from a hypervisor guest are also a potential attack
1125 on overall system integrity since they often have elevated privilege levels above the hypervisor itself. This is another
1126 means that an attacker on the bootloader could gain persistence on the system after the bootloader has passed control to
1127 the operating system.

1128 Audit and security event logs may be targeted by attackers to hide evidence of boot compromise. Loss of audit log
1129 integrity prevents forensic investigation and attack detection.

1130 4.7.4 Availability

1131 If an attacker changes any of the boot configuration in a verified boot system, the device may no longer boot and might
1132 not be accessible by the user. Depending on when during the boot process the configuration verification fails,
1133 communicating the nature of the failure to the user may be challenging. System designers should consider recovery
1134 flows for re-establishing trust in the device if the bootloader verification fails.

1135 Corruption of rollback protection, measurement data, or runtime state can cause boot failures. Critical asset
1136 unavailability can render the system unbootable, creating support and recovery challenges.

1137 4.7.5 Impact of other devices

1138 Integrity failures during the bootloader process can leave the attacker in a position to interfere with other devices on the
1139 network or future components in the boot chain.

1140 Availability failures could lead to a boot loop where the bootloader continuously tries to authenticate with a remote
1141 server.

1142 4.7.6 Assets requiring protection

1143 4.7.6.1 A-CRYPT: Cryptographic keys and certificates

1144 Keys and certificates establishing trust in the boot chain. Compromise enables signing malicious code as legitimate or
1145 decrypting protected data.

- 1146 • Root verification keys (platform keys, root certificates).

- 1147 • Signature database.
- 1148 • Device attestation keys.
- 1149 • Symmetric encryption keys.
- 1150 • Revocation data.
- 1151 NOTE: Platform keys require special attention due to supply chain risks including default keys and key leakage.
- 1152 See T-SUPPLY-6.

1153 4.7.6.2 A-ROLLBACK: Rollback protection data

- 1154 Counters and version information that prevent downgrade to vulnerable versions. Compromise enables rollback attacks
1155 where attackers exploit known patched vulnerabilities.
- 1156 • Version counters (monotonic, non-decreasing).
 - 1157 • Minimum version numbers.
 - 1158 • Anti-rollback enforcement data.

1159 4.7.6.3 A-CONFIG: Configuration data

- 1160 Settings that control boot manager security behaviour. Compromise allows attackers to weaken security policies or
1161 enable unauthorized boot paths.
- 1162 • Security policy settings.
 - 1163 • Trust anchor configuration.
 - 1164 • Boot device selection and priority.
 - 1165 • Network boot credentials (when present).
 - 1166 • Recovery mode settings.
 - 1167 • Debug interface lockdown state.
 - 1168 • Parsed input data (e.g. boot images, logo images, UEFI variables, configuration files).
 - 1169 NOTE: Parsed input is attack surface for parser vulnerabilities. See T-INTEGRITY-14.

1170 4.7.6.4 A-AUTH: Authentication credentials

- 1171 Credentials controlling access to boot manager configuration and recovery functions. Compromise enables unauthorized
1172 configuration changes and security policy modifications.
- 1173 • Setup/BIOS passwords (hashed).
 - 1174 • Administrator passwords (hashed).
 - 1175 • Physical presence authentication tokens.
 - 1176 • Recovery authentication data.

1177 4.7.6.5 A-MEASURE: Measurement and attestation data

- 1178 Records of boot components and configuration for remote verification. Compromise allows attackers to hide malicious
1179 modifications and appear trustworthy during attestation.
- 1180 • Event log.
 - 1181 • Measurement metadata (component identities, versions, algorithms used).

1182 4.7.6.6 A-AUDIT: Audit logs

1183 Records of security-relevant events during boot. Compromise allows attackers to hide evidence of attacks and prevent
1184 detection or forensic investigation.

- 1185 • Verification success/failure events.
- 1186 • Authentication attempts.
- 1187 • Configuration change records.
- 1188 • Security policy violation attempts.
- 1189 • Recovery mode activation events.

1190 4.7.6.7 A-RUNTIME: Runtime state data

1191 Security state during boot execution. Compromise enables attackers to bypass security checks, manipulate boot
1192 decisions, or enable unlimited authentication attempts.

- 1193 • Security mode state (setup mode, user mode, deployed mode).
- 1194 • Verification completion flags.
- 1195 • Boot attempt counters.
- 1196 • Memory protection configuration.
- 1197 • Boot phase state machine.

1198 NOTE: State transitions are attack surface for privilege escalation. See T-INTEGRITY-15.

1199 4.7.6.8 A-CODE: Boot manager executable code

1200 The boot manager code itself while executing or staged for update. Compromise provides persistent privileged access
1201 and complete control over boot process.

- 1202 • Boot manager code in writable memory during execution.
- 1203 • Runtime services code (if persisting after boot target handoff).
- 1204 • Update staging area contents.

1205 4.7.6.9 A-UPDATE: Update packages and delivery mechanisms

1206 Update packages during delivery, staging, and installation, plus update tooling.

- 1207 • Update packages in transit.
- 1208 • Staged updates awaiting installation.
- 1209 • Update signature metadata.
- 1210 • Update verification tools.
- 1211 • Update delivery infrastructure trust anchors.

1212 NOTE: Update tools themselves are attack targets (BIOS Disconnect). See T-INTEGRITY-16, T-SUPPLY-7.

1213 4.7.7 Threat categories

1214 4.7.7.0 Introduction to threat categories

1215 Boot managers face threat categories organized by attack vector and persistence mechanism. Requirements in clause 5
1216 mitigate specific threats within these categories. Clause B.3 provides the complete threat catalogue with specific threat
1217 identifiers.

1218 Each threat category contains specific threats identified by formal identifiers (e.g. T-INTEGRITY-1, T-NET-4).
1219 Requirements reference these specific identifiers to enable traceable threat mitigation. Threat relevance is determined
1220 by product capabilities per clause B.3, and threat exposure level is determined by risk factors per clause 4.7.8. The
1221 threat identification methodology is documented in clause B.2.

1222 4.7.7.1 T-INTEGRITY: Boot integrity attacks

1223 Boot integrity attacks target the authenticity and trustworthiness of boot components, attempting to execute
1224 unauthorized code, weaken security policies, bypass verification mechanisms, or exploit parsing and input validation
1225 weaknesses. These attacks undermine the fundamental trust establishment role of the boot manager.

1226 See clause B.3.1 for complete threat enumeration.

1227 4.7.7.2 T-PERSIST: Persistent firmware threats

1228 Persistent firmware threats establish malware or compromise that survives operating system reinstallation, disk
1229 formatting, and traditional security remediation. These threats exploit the boot manager's position below the operating
1230 system to maintain long-term system compromise.

1231 See clause B.3.2 for complete threat enumeration.

1232 4.7.7.3 T-PHYS: Physical attacks

1233 Physical attacks require direct hardware access to the device. These attacks exploit physical proximity to extract secrets,
1234 modify hardware, inject faults, replace components, or manipulate power state transitions. The physical security
1235 boundary varies significantly based on deployment context and boot source capabilities.

1236 See clause B.3.3 for complete threat enumeration.

1237 4.7.7.4 T-SUPPLY: Supply chain attacks

1238 Supply chain attacks compromise boot manager security during manufacturing, development, distribution, or update
1239 processes. These attacks exploit trust relationships between manufacturers, component suppliers, key management
1240 practices, and update infrastructure.

1241 See clause B.3.4 for complete threat enumeration.

1242 4.7.7.5 T-NET: Network-based attacks

1243 Network-based attacks exploit network connectivity during boot, update, or configuration processes. These attacks
1244 provide remote attack surface without requiring physical access, occurring before operating system security
1245 mechanisms are active.

1246 See clause B.3.5 for complete threat enumeration.

1247 4.7.7.6 T-AVAIL: Availability and resilience threats

1248 Availability and resilience threats prevent successful boot completion, cause denial of service, or undermine recovery
1249 mechanisms that ensure operational continuity. These threats exploit resource limitations, configuration dependencies,
1250 or network infrastructure failures to prevent the boot manager from fulfilling its core function.

1251 See clause B.3.6 for complete threat enumeration.

4.7.8 Risk factors

4.7.8.0 Introduction to risk factors

Risk factors characterize deployment context to determine threat exposure levels. Six factors capture impact severity and attack likelihood for threats identified in clause B.3.

4.7.8.1 Impact factors

RF-SAFE: Safety and infrastructure impact

Higher levels indicate potential for physical harm or critical service disruption if compromised or malfunctioning.

Table 4.7.8.1-1: Safety and infrastructure impact levels

Level	Description	Examples
0	No safety impact, limited availability impact	Consumer entertainment, development boards
1	Minor operational disruption, no safety impact	Office equipment, personal devices
2	Significant operational impact, infrastructure dependency	Network infrastructure, building automation
3	Safety-critical or essential infrastructure	Medical devices, industrial control, transportation

RF-DATA: Data sensitivity Higher levels indicate stricter protection obligations and greater attacker interest.

Table 4.7.8.1-2: Data sensitivity levels

Level	Description	Examples
0	No sensitive data processed	Standalone sensors, public displays
1	Personal data, limited confidentiality	Consumer IoT, home automation
2	Confidential business data, financial information	Enterprise systems, payment terminals
3	Highly sensitive data, regulatory requirements	Healthcare records, classified information

4.7.8.2 Likelihood factors

RF-ATK: Attacker motivation and capability

Higher levels indicate greater attacker investment and more advanced techniques.

Table 4.7.8.2-1: Attacker motivation and capability levels

Level	Description	Examples
1	Opportunistic, low effort	Script kiddies, commodity malware, mass scanning
2	Targeted, moderate investment	Organized crime, corporate espionage, ransomware gangs
3	Strategic, high investment	Critical infrastructure targeting, state-sponsored, advanced persistent threats

RF-NET: Network exposure

Higher levels indicate greater remote attack surface.

Table 4.7.8.2-2: Network exposure levels

Level	Description	Examples
1	Air-gapped or isolated network	Industrial control systems, secure facilities
2	Internal network with perimeter security	Enterprise environments, managed networks
3	Direct internet exposure	Edge devices, public-facing servers, consumer IoT

RF-PHYS: Physical accessibility

Higher levels indicate greater exposure to hardware-based attacks.

Table 4.7.8.2-3: Physical accessibility levels

Level	Description	Examples
1	Restricted physical access, monitored	Data centres, secure facilities
2	Semi-controlled access	Office environments, retail locations
3	Public or uncontrolled access	ATMs, kiosks, consumer devices, field deployment

RF-PATCH: Remediation capability

Higher levels indicate longer exposure windows to address vulnerabilities.

Table 4.7.8.2-4: Remediation capability levels

Level	Description	Examples
1	Rapid remediation (days to weeks)	Consumer devices with auto-update, cloud-managed
2	Delayed remediation (weeks to months)	Enterprise with testing cycles, maintenance windows
3	Rare or no remediation (months to years)	Air-gapped systems, certification constraints, immutable firmware

NOTE: Long-lifetime deployments (RF-PATCH = 3, >15 years) face elevated risk from vulnerability accumulation without remediation, update infrastructure decay, hardware security component degradation, and attack technique evolution. These conditions amplify other threat categories rather than constituting distinct attacks. Products should consider threat evolution scenarios during design.

4.7.8.3 Risk level determination

Risk level is determined by impact factors with likelihood modifiers.

HIGH if:

- Impact factor = 3, or
- Impact factor ≥ 2 combined with any likelihood factor = 3

MEDIUM if:

- Impact factor = 2, or
- Likelihood factors sum ≥ 8

LOW otherwise.

Where:

- Impact factors: RF-SAFE, RF-DATA
- Likelihood factors: RF-ATK, RF-NET, RF-PHYS, RF-PATCH

NOTE: Impact factors dominate risk determination. HIGH impact deployments require HIGH risk treatment regardless of likelihood factors. The likelihood sum threshold captures scenarios where multiple moderate exposure factors combine to elevate overall risk.

4.8 Representative use cases

4.8.1 Purpose

Use cases illustrate how deployment context influences risk assessment. Each use case reflects a combination of intended purpose, reasonably foreseeable use, and operational environment that determines applicable risk factors. Manufacturers use these examples to identify which use case most closely matches their product's deployment context, then assess risk factors accordingly. Requirements in clause 5 apply based on the resulting risk level.

Risk level determination follows clause 4.7.8. Use cases do not constitute normative product categories.

Table 4.8.1-1: Use cases

UC	Name	Risk	Typical capabilities
UC-L1	Immutable embedded	LOW	None (ROM-only)
UC-L2	Updateable IoT/consumer	LOW	Updates, basic config
UC-M1	Consumer/SMB computing	MEDIUM	Verified boot, logging, config, updates
UC-M2	Enterprise managed	MEDIUM	Full suite: measured boot, network boot, HSS
UC-H1	Critical systems	HIGH	Maximum: HSS, HSE, full management

4.8.2 UC-L1: Immutable embedded

Boot manager in isolated devices with no update capability and fixed configuration. Code is immutable after manufacture.

Examples: Environmental sensors, simple embedded controllers, basic IoT sensors, electronic toys, ROM-based microcontrollers.

Capabilities: No updates, no configuration, no logging, no recovery.

4.8.3 UC-L2: Updateable IoT and consumer

Boot manager in connected consumer devices with update capability and basic configuration. Limited security features appropriate for non-sensitive applications.

Examples: Smart TVs, gaming consoles, smart home devices, e-readers, consumer appliances, development boards.

Capabilities: Updates, basic configuration, optional: verified boot, logging.

4.8.4 UC-M1: Consumer and SMB computing

Boot manager in general-purpose computing devices storing personal or business data. Verified boot and logging enable security monitoring.

Examples: Laptops, desktops, tablets, smartphones, small business servers, NAS devices, connected vehicles.

Capabilities: Verified boot, logging, configuration, updates. Optional: recovery, authentication.

4.8.5 UC-M2: Enterprise managed

Boot manager in enterprise infrastructure under centralized management. Full management suite enables policy enforcement and attestation.

Examples: Enterprise workstations, servers, network infrastructure, virtualization hosts, managed endpoints.

Capabilities: Verified boot, measured boot, network boot, logging, configuration, authentication, recovery. Optional: hardware security storage.

1331 4.8.6 UC-H1: Critical systems

1332 Boot manager in systems where compromise causes safety impact, critical service disruption, or severe data breach.
1333 Maximum security controls with hardware enforcement.

1334 **Examples:** Medical devices, industrial control systems, financial infrastructure, government systems,
1335 telecommunications infrastructure, critical facility management.

1336 **Capabilities:** Full suite including hardware security storage and hardware security enforcement. > NOTE: UC-H1
1337 includes varied deployment contexts (connected vs isolated, healthcare vs industrial). Manufacturers conduct detailed
1338 risk assessment per clause 4.7.8 based on specific deployment.

1339 4.8.7 Use case capabilities

1340 **Table 4.8.7-1: Use case capabilities**

Capability	UC-L1	UC-L2	UC-M1	UC-M2	UC-H1
Verified boot	-	(X)	X	X	X
Measured boot	-	-	(X)	X	X
Network boot	-	-	(X)	X	(X)
Update capability	NO	X	X	X	X
Configuration	-	(X)	X	X	X
Logging	-	-	X	X	X
Recovery	-	-	(X)	X	X
Authentication	-	-	(X)	X	X
HW security storage	-	-	-	(X)	X
HW security enforcement	-	-	-	(X)	X
Debug interface	-	(X)	-	-	-

Legend: X = Typically present | (X) = Sometimes present | - = Typically absent | NO = Explicitly absent.

1341

1342 4.8.8 Use case selection

1343 Manufacturers identify the representative use case that most closely matches their product's intended deployment
1344 context. The selected use case provides typical risk factors which determine threat exposure levels per clause 4.7.8.

1345 When deployment context spans multiple use cases, manufacturers select the higher risk level as conservative approach.
1346 Manufacturers document:

- 1347 • Selected use case with rationale.
- 1348 • Risk factor validation against actual deployment.
- 1349 • Any deviations from typical capability profile.

1350 NOTE: Products not aligning with any use case may require manufacturer-specific risk assessment per
1351 clause 4.7.8.

1352 **Table 4.8.8-1: Risk factors**

Risk factor	UC-L1	UC-L2	UC-M1	UC-M2	UC-H1
RF-SAFE	0	0	1	2	3
RF-DATA	0	1	2	2	3
RF-ATK	1	1	1	2	3
RF-NET	1	3	3	2	1-2
RF-PHYS	3	3	3	1	1-2
RF-PATCH	3	1	1	2	2-3
Risk level	LOW	LOW	MEDIUM	MEDIUM	HIGH

1353

5 Requirements

5.1 Requirement framework

This clause establishes cybersecurity requirements implementing Annex I Part I and Part II of Regulation (EU) 2024/2847 [i.1].

Requirements apply based on risk level (LOW, MEDIUM, HIGH) derived from deployment context assessment per clause 4.7.8, ensuring cybersecurity measures are proportionate to identified risks and fit for purpose. Product capabilities (verified boot, updatability, configuration capability, etc.) determine additional applicability conditions. Each requirement explicitly specifies its applicability.

Requirements address boot manager security properties including initial trust establishment without prior security infrastructure, operation under resource constraints, and protection against persistent compromise.

5.2 Security by Design

5.2.0 Introduction to Security by design requirements

This clause addresses CRA requirements for secure design, development, and production. Boot manager security architecture need to integrate protective measures from initial design through implementation, considering pre-OS constraints, limited resources, and critical boot integrity requirements. This clause implements the principle of security by design as defined in prEN 40000-1-2 [2].

5.2.1 [RQ-SBD-001]

Requirement: The boot manager shall isolate boot components using memory protection, privilege separation, or hardware isolation mechanisms available on platform.

Applicability: Applies to all boot managers.

5.2.2 [RQ-SBD-002]

Requirement: The boot manager shall restrict access to cryptographic key material to authorized boot components as defined by the boot manager's security policy.

Applicability: Applies to all boot managers using cryptographic keys.

5.2.3 [RQ-SBD-003]

Requirement: The boot manager shall, before handing off control to the boot target, ensure that only the resources necessary for the boot target remain enabled.

Applicability: Applies to all boot managers.

NOTE: Examples of resources that may need to be disabled or released include, but are not limited to:

- a) debug or diagnostic interfaces;
- b) DMA-capable devices or peripherals;
- c) hardware resources not required by the boot target;
- d) allocated volatile memory;
- e) network or communication buffers; and
- f) memory regions that are not required for the operation of the boot target.

1389 5.2.4 [RQ-SBD-004]

1390 **Requirement:** The boot manager shall enforce privilege boundaries so that code executed in one boot stage cannot
1391 obtain privileges assigned to another boot stage or cross established trust boundaries.

1392 **Applicability:** Applies to all boot managers.

1393 NOTE: Examples of privilege boundaries include: a) restrictions on access to memory regions; b) restrictions on
1394 execution of privileged instructions; c) limitations on access to security-sensitive hardware resources.

1395 5.2.5 [RQ-SBD-005]

1396 **Requirement:** Device-specific keys shall be used for symmetric verified or measured boot operations. The use of
1397 global symmetric keys for verified or measured boot purposes is explicitly forbidden.

1398 **Applicability:** Applies to all boot managers implementing verified boot or measured boot.

1399 NOTE: Use of symmetric device-unique keys mitigates the risk of large-scale attacks resulting from compromise
1400 of a single global key.

1401 5.3 Secure by Default Configuration

1402 5.3.0 Introduction to secure by default configuration requirements

1403 This clause addresses CRA requirements for secure default configuration. Boot managers shall be put on the market
1404 with security features enabled, no default credentials, and protection matching available hardware and software
1405 resources. This clause implements the principle of secure by default as defined in prEN 40000-1-2 [2].

1406 NOTE: The technical implementation of security features (i.e. digital signature validation, or authenticated hash
1407 verification, logging capabilities, rollback protection) and the responsibility for enabling them by default
1408 may vary depending on the deployment model, device capabilities, and security policy. In many cases, the
1409 OEM or system integrator is responsible for activating these features during device configuration, rather
1410 than the silicon supplier, that is in charge to provide those features.

1411 5.3.1 [RQ-DEFAULT-001]

1412 **Requirement:** The boot manager shall enable cryptographic validation by default.

1413 **Applicability:** Applies to all boot managers with verified boot.

1414 NOTE: See clause 5.3, General considerations, for details on implementation and activation responsibilities.

1415 5.3.2 [RQ-DEFAULT-002]

1416 **Requirement:** The boot manager shall not implement unauthorized or undocumented mechanisms that allow bypassing
1417 authentication or security controls.

1418 **Applicability:** Applies to all boot managers.

1419 NOTE: Examples of such mechanisms include: a) default or hardcoded passwords; b) maintenance or service
1420 backdoors; c) undocumented access interfaces or commands.

1421 5.3.3 [RQ-DEFAULT-003]

1422 **Requirement:** When passwords are used for authentication, the boot manager shall require the credentials to be
1423 established during initial deployment.

1424 **Applicability:** Applies to all boot managers with configuration capability using password authentication.

1425 5.3.4 [RQ-DEFAULT-004]

1426 **Requirement:** The boot manager shall prevent automatic fallback to less secure boot modes.

1427 **Applicability:** Applies to all boot managers with verified or measured boot.

1428 5.3.5 [RQ-DEFAULT-005]

1429 **Requirement:** When a user interface is available, the boot manager shall provide a user-visible indication when a
1430 security-relevant protection is reduced or disabled.

1431 **Applicability:** Applies to all boot managers with configuration capability.

1432 5.3.6 [RQ-DEFAULT-006]

1433 **Requirement:** The boot manager shall support restoring the system to secure default configuration settings.

1434 **Applicability:** Applies to all boot managers with configuration capability.

1435 5.4 Authentication and Authorization

1436 5.4.0 Introduction to authentication and authorization requirements

1437 This clause addresses CRA requirements for access control and authentication. Boot managers control code execution
1438 authorization and configuration protection through cryptographic verification, physical presence detection, and
1439 hardware-based protections.

1440 5.4.1 [RQ-AUTH-001]

1441 **Requirement:** The boot manager shall require that any configuration changes to trusted keys, certificates, or trust
1442 anchor databases are authorized only through one of the following mechanisms: (a) direct physical presence at the
1443 device; or (b) submission of a signed artefact whose authenticity and integrity are cryptographically verified by the boot
1444 manager prior to application.

1445 **Applicability:** Applies to all boot managers with configuration capability.

1446 5.4.2 [RQ-AUTH-002]

1447 **Requirement:** The boot manager shall protect configuration settings related to the boot process against unauthorized
1448 modification.

1449 **Applicability:** Applies to all boot managers with configuration capability.

1450 NOTE: In embedded system scenarios, replacing or revoking trusted keys or certificates is often performed via
1451 authenticated software updates, without requiring physical presence. NOTE 2: Examples of configuration
1452 settings related to the boot process include: a) boot order; b) boot parameters; c) selection of boot targets
1453 or modes.

1454 5.4.3 [RQ-AUTH-003]

1455 **Requirement:** The boot manager shall require explicit user action and authentication before any modification of
1456 security-critical configuration settings.

1457 **Applicability:** Applies to all boot managers with configuration capability.

1458 NOTE: Examples of such actions include: a) weakening or disabling secure default settings; b) downgrading
1459 security-related configuration parameters; c) modifying security-critical options such as verification
1460 policies or trust anchors.

1461 5.4.4 [RQ-AUTH-004]

1462 **Requirement:** When passwords are used for authentication, the boot manager shall limit authentication attempts with
1463 hardware bound throttling (limit tries or increase delays, or via cryptographically designed to be slow key derivation
1464 functions, where passwords are used.

1465 **Applicability:** Applies to all boot managers with configuration capability using password authentication.

1466 5.4.5 [RQ-AUTH-005]

1467 **Requirement:** The boot manager shall verify the authenticity and integrity of boot security configuration policies
1468 before applying them.

1469 **Applicability:** Applies to all boot managers with verified boot and configuration capability.

1470 5.4.6 [RQ-AUTH-006]

1471 **Requirement:** The boot manager shall indicate when running with modified policies through persistent visual
1472 indication or, where logging capability is supported, through logged events.

1473 **Applicability:** Applies to all boot managers with configuration capability.

1474 NOTE 1: The indication may be visual (when a user interface is available) or may consist of recorded events in
1475 secure logs.

1476 NOTE 2: Examples of indications include: a) a persistent on-screen message or icon; b) a status LED or display
1477 element; c) a logged event recorded in a secure audit log.

1478 5.4.7 [RQ-AUTH-007]

1479 **Requirement:** The boot manager shall protect trusted certificate stores from unauthorized modification.

1480 **Applicability:** Applies to all boot managers with verified boot.

1481 5.5 Confidentiality

1482 5.5.0 Introduction to confidentiality requirements

1483 This clause addresses CRA requirements for data confidentiality. Boot managers shall protect cryptographic key
1484 material, credentials, and security policies in resource-constrained environments against persistent physical access
1485 threats.

1486 5.5.1 [RQ-CONFID-001]

1487 **Requirement:** The boot manager shall prevent key material from being used for cryptographic purposes other than
1488 those for which it was designated.

1489 **Applicability:** Applies to all boot managers with verified or measured boot.

1490 5.5.2 [RQ-CONFID-002]

1491 **Requirement:** The boot manager shall prevent sensitive data from being included in crash dumps or logs.

1492 **Applicability:** Applies to all boot managers with logging capability.

1493 NOTE: Examples of sensitive data include: a) cryptographic key material; b) authentication credentials; c)
1494 security-critical configuration parameters; d) personal or otherwise confidential information managed
1495 during the boot process.

1496 5.5.3 [RQ-CONFID-003]

1497 **Requirement:** The boot manager shall protect stored credentials using approved mechanisms that prevent recovery of
1498 the original credential values.

1499 **Applicability:** Applies to all boot managers with configuration and recovery capability.

1500 NOTE 1: Examples of protected credential types include user passwords, recovery keys, and other authentication
1501 secrets.

1502 NOTE 2: Examples of protection mechanisms include: a) key-derivation functions (e.g. salted password hashing);
1503 b) hardware-bound storage or sealed storage; c) encryption using keys not accessible to unauthorized
1504 entities; d) key-wrapping or secret-derivation schemes.

1505 5.5.4 [RQ-CONFID-004]

1506 **Requirement:** The boot manager shall protect network boot parameters containing authentication information using
1507 approved mechanisms that prevent unauthorized disclosure.

1508 **Applicability:** Applies to all boot managers with configuration capability and network boot.

1509 5.5.5 [RQ-CONFID-005]

1510 **Requirement:** The boot manager shall cryptographically erase all sensitive data and clear all security-critical
1511 configuration during secure disposal, where technically feasible.

1512 **Applicability:** Applies to all boot managers with verified boot and configuration capability.

1513 NOTE: When cryptographic material or sensitive data are stored in immutable components such as e-fuses or
1514 ROM, complete erasure may not be possible.

1515 5.5.6 [RQ-CONFID-006]

1516 **Requirement:** When secure disposal is supported, the boot manager shall provide an indication upon successful
1517 completion of the sanitization process.

1518 **Applicability:** Applies to all boot managers.

1519 5.5.7 [RQ-CONFID-007]

1520 **Requirement:** The boot manager shall protect the confidentiality and integrity of boot configuration data transmitted
1521 over network.

1522 **Applicability:** Applies to all boot managers with network boot.

1523 5.5.8 [RQ-CONFID-008]

1524 **Requirement:** The boot manager shall overwrite confidential or secret data after use, clear from memory temporary
1525 data structures and credentials before boot target handoff and not persist authentication credentials or confidential
1526 cryptographic material beyond the current boot cycle.

1527 **Applicability:** Applies to all boot managers.

1528 NOTE 1: Examples of sensitive data include authentication credentials, cryptographic key material, and temporary
1529 data structures created during the boot process.

1530 NOTE 2: Examples of mechanisms for removing sensitive data include: a) overwriting sensitive data after use; b)
1531 clearing temporary data structures and credentials before handing off control to the boot target; c)
1532 avoiding persistence of authentication credentials or cryptographic material across boot cycles.

1533 5.6 Integrity Protection

1534 5.6.0 Introduction to integrity protection requirements

1535 This clause addresses CRA requirements for data and system integrity. Boot managers establish trust chains through
1536 cryptographic verification, measurement, and protection mechanisms that resist component substitution, rollback, and
1537 TOCTOU attacks.

1538 5.6.1 [RQ-INTEGRITY-001]

1539 **Requirement:** The boot manager shall verify integrity and authenticity of each boot stage using approved
1540 cryptographic mechanisms and shall establish a chain of trust to a root trust anchor before transferring control.

1541 **Applicability:** Applies to all boot managers with verified boot.

1542 5.6.2 [RQ-INTEGRITY-002]

1543 **Requirement:** The boot manager shall prevent boot continuation with components that fail integrity or authenticity
1544 verification.

1545 **Applicability:** Applies to all boot managers with verified boot.

1546 NOTE 1: Examples of verification failures include: a) invalid, expired, or revoked cryptographic credentials; b)
1547 substituted or tampered components; c) missing or untrusted verification data.

1548 NOTE 2: Cryptographic verification mechanisms may include digital signatures, message authentication codes
1549 (MACs), or other approved methods providing equivalent assurance.

1550 5.6.3 [RQ-INTEGRITY-003]

1551 **Requirement:** The boot manager shall verify component provenance through certificates and check component
1552 compatibility and version consistency.

1553 **Applicability:** Applies to all boot managers with verified boot.

1554 5.6.4 [RQ-INTEGRITY-004]

1555 **Requirement:** The boot manager shall verify authenticity and integrity of update packages before installation and after
1556 network transfer.

1557 **Applicability:** Applies to all boot managers with update capability.

1558 5.6.5 [RQ-INTEGRITY-005]

1559 **Requirement:** The boot manager shall detect unauthorized firmware modifications using defence-in-depth verification
1560 mechanisms.

1561 **Applicability:** Applies to all boot managers with verified boot.

1562 NOTE: Defence-in-depth may include multiple, independent integrity or authenticity checks.

1563 5.6.6 [RQ-INTEGRITY-006]

1564 **Requirement:** When hardware security components are unavailable, the boot manager shall implement software-based
1565 cryptographic verification with keys stored in protected storage.

1566 **Applicability:** Applies to all boot managers with verified boot.

1567 5.6.7 [RQ-INTEGRITY-007]

1568 **Requirement:** The boot manager shall maintain a configurable list of approved signing algorithms.

1569 **Applicability:** Applies to all boot managers with verified boot and configuration capability.

1570 5.6.8 [RQ-INTEGRITY-008]

1571 **Requirement:** The boot manager shall support multiple signature algorithms.

1572 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with verified boot.

1573 5.6.9 [RQ-INTEGRITY-009]

1574 **Requirement:** The boot manager shall require authentication before allowing verification bypass.

1575 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with verified boot.

1576 5.6.10 [RQ-INTEGRITY-010]

1577 **Requirement:** The boot manager shall prevent unauthorized modification between verification and execution.

1578 **Applicability:** Applies to all boot managers.

1579 5.6.11 [RQ-INTEGRITY-011]

1580 **Requirement :** The boot manager shall load components into protected memory before verification, when supported by
1581 the underlying hardware platform.

1582 **Applicability:** Applies to all boot managers with verified boot.

1583 5.6.12 [RQ-INTEGRITY-012]

1584 **Requirement:** The boot manager shall protect sensitive configuration settings with hardware protected storage or
1585 authenticated encryption which employs freshness protection and non-deterministic encryption.

1586 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with configuration capability.

1587 5.6.13 [RQ-INTEGRITY-013]

1588 **Requirement:** The boot manager shall restore secure default configuration settings when configuration corruption is
1589 detected, where technically feasible.

1590 **Applicability:** Applies to all boot managers with configuration capability.

1591 NOTE: When cryptographic material or configuration data are stored in immutable components such as e-fuses or
1592 ROM, complete erasure or restoration may not be possible.

1593 5.6.14 [RQ-INTEGRITY-014]

1594 **Requirement:** The boot manager shall authenticate network boot servers using cryptographic certificates, when boot
1595 servers are authorized to launch actions or provide unauthenticated data or configuration.

1596 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with network boot.

1597 5.6.15 [RQ-INTEGRITY-015]

1598 **Requirement:** The boot manager shall reject network boot connections with invalid, expired, or revoked server
1599 certificates.

1600 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with network boot.

1601 5.6.16 [RQ-INTEGRITY-016]

1602 **Requirement:** The boot manager shall verify that network configuration and boot-related responses originate from
1603 authorized infrastructure.

1604 **Applicability:** Applies to all boot managers with network boot.

1605 NOTE: Examples of network configuration and boot-related responses include: a) DHCP responses; b) PXE boot
1606 offers; c) network-provided boot configuration data.

1607 5.6.17 [RQ-INTEGRITY-017]

1608 **Requirement:** The boot manager shall enforce rollback protection for firmware and security configuration by default.

1609 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with update or configuration capability.

1610 NOTE: In some business models, anti-rollback protection can be configured by the OEM. Refer to note in clause
1611 5.3.

1612 5.6.18 [RQ-INTEGRITY-018]

1613 **Requirement:** The boot manager shall store anti-rollback counters in hardware-backed or tamper-evident storage and
1614 verify signed version metadata before accepting updates.

1615 **Applicability:** Applies to HIGH risk boot managers with update capability.

1616 5.6.19 [RQ-INTEGRITY-019]

1617 **Requirement:** The boot manager shall verify certificate chains against a trusted root before using certificates for
1618 security-relevant operations.

1619 **Applicability:** Applies to all boot managers with verified boot.

1620 NOTE: Certificate-chain verification may include checking: a) the full chain of trust from the end-entity
1621 certificate to the trusted root; b) certificate validity periods; c) revocation status through mechanisms such
1622 as CRLs or OCSP; d) compliance with certificate policies or usage constraint.

1623 5.6.20 [RQ-INTEGRITY-020]

1624 **Requirement:** The boot manager shall support revocation of compromised keys and certificates through a revocation
1625 database or configuration updates.

1626 **Applicability:** Applies to all boot managers with verified boot.

1627 NOTE 1: In boot managers without connectivity capability, revocation can be managed manually (e.g. via
1628 dedicated tools or physical programming) or through authenticated software updates.

1629 NOTE 2: In many embedded systems, the number of revocation slots (especially for verified boot) is limited by
1630 available storage or hardware design, so the number of possible key revocations may be constrained.

1631 NOTE 3: Revocation mechanisms may include: a) a revocation database; b) configuration or policy updates; c)
1632 certificate revocation lists (CRLs); d) online or offline status information (e.g. OCSP responses); e)
1633 manufacturer- or owner-provided revocation metadata.

1634 5.6.21 [RQ-INTEGRITY-021]

1635 **Requirement:** The boot manager shall use cryptographic algorithms, key sizes, and parameters listed in ECCG Agreed
1636 Cryptographic Mechanisms [3] or demonstrably equivalent state-of-the-art mechanisms.

1637 **Applicability:** Applies to all boot managers.

1638 5.6.22 [RQ-INTEGRITY-022]

1639 **Requirement:** The boot manager shall support cryptographic agility.

1640 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with update capability.

1641 NOTE: Mechanisms enabling cryptographic agility may include: a) updateable trust anchors; b) support for
1642 multiple approved cryptographic algorithms; c) metadata allowing controlled algorithm selection or
1643 migration.

1644 5.6.23 [RQ-INTEGRITY-023]

1645 **Requirement:** The boot manager shall use collision- and preimage-resistant one-way functions for origin authentication
1646 and verification of boot code provenance.

1647 **Applicability:** Applies to all boot managers with verified or measured boot capability.

1648 NOTE 1: Examples of collision- and preimage-resistant one-way functions include SHA-2 and SHA-3

1649 NOTE 2: Non-collision-resistant hashes (e.g. GHASH in AES-GCM) may be used for integrity protection only
1650 when combined with device-specific keys

1651 5.7 Data Minimization

1652 5.7.0 Introduction to data minimization requirements

1653 This clause addresses CRA requirements for data minimization. Boot managers shall process only data necessary for
1654 boot operations, security verification, and error indication, given memory and storage constraints.

1655 5.7.1 [RQ-MINIMAL-001]

1656 **Requirement:** The boot manager shall minimize disclosure of information to network infrastructure by limiting
1657 transmitted data to what is necessary for boot operations.

1658 **Applicability:** Applies to all boot managers with network boot.

1659 NOTE: Examples of measures to minimize network disclosure include: a) requesting only the files required for
1660 the network boot process; b) negotiating only protocol parameters essential for establishing the boot
1661 session; c) restricting identifiers exposed on the network (e.g. to MAC address and device class).

1662 5.7.2 [RQ-MINIMAL-002]

1663 **Requirement:** The boot manager shall prevent disclosure of sensitive device information and shall ensure that
1664 temporary network credentials are not retained beyond their required use.

1665 **Applicability:** Applies to all boot managers with network boot.

1666 NOTE: Examples of sensitive device information that should not be disclosed include:

- 1667 a) firmware version information;
- 1668 b) hardware serial numbers;
- 1669 c) internal configuration or diagnostic data.

1670 5.7.3 [RQ-MINIMAL-003]

1671 **Requirement:** The boot manager shall limit configuration storage to information necessary for boot and
1672 security-related operations.

1673 **Applicability:** Applies to all boot managers with configuration capability.

1674 NOTE: Examples of information that may be necessary include: a) essential boot parameters; b) security policy
1675 settings; c) boot device priorities,

1676 5.8 Availability and Resilience

1677 5.8.0 Introduction to availability and resilience requirements

1678 This clause addresses CRA requirements for availability and resilience. Boot managers shall maintain availability
1679 during failures or attacks through recovery mechanisms, failsafe operations, and resistance to denial-of-service
1680 conditions.

1681 Where this clause specifies limits without numeric values, the manufacturer shall document specific thresholds in
1682 security documentation per Annex C.

1683 5.8.1 [RQ-AVAIL-001]

1684 **Requirement:** The boot manager shall support fallback to previous known-good configuration.

1685 **Applicability:** Applies to all boot managers with configuration capability.

1686 5.8.2 [RQ-AVAIL-002]

1687 **Requirement:** The boot manager shall support redundant boot paths.

1688 **Applicability:** Applies to HIGH risk boot managers.

1689 5.8.3 [RQ-AVAIL-003]

1690 **Requirement:** The boot manager shall enforce timeouts to prevent indefinite blocking during boot-related operations.

1691 **Applicability:** Applies to all boot managers.

1692 NOTE: Examples of operations that may require timeouts include: a) parsing or validation of configuration data;
 1693 b) network discovery, negotiation, or file retrieval; c) loading or verifying boot components.

1694 5.8.4 [RQ-AVAIL-004]

1695 **Requirement:** The boot manager shall limit retry attempts and resource consumption for signature verification and
 1696 network operations.

1697 **Applicability:** Applies to all boot managers.

1698 5.8.5 [RQ-AVAIL-005]

1699 **Requirement:** The boot manager shall prevent unauthorized bypass of security verification steps during normal
 1700 operation.

1701 **Applicability:** Applies to all boot managers.

1702 NOTE: In specific, controlled scenarios such as in-field debug mode, disabling security verification steps may be
 1703 permitted for issue analysis, provided that such actions are strictly authenticated.

1704 5.8.6 [RQ-AVAIL-006]

1705 **Requirement:** The boot manager shall detect and correct errors in critical data (e.g. cryptographic keys, configuration
 1706 data) using appropriate mechanisms, if supported by the underlying platform.

1707 **Applicability:** Applies to MEDIUM and HIGH risk boot managers.

1708 NOTE: If critical data is stored in immutable elements such as e-fuses, error correction can be implemented using
 1709 Forward Error Correction (FEC) codes or similar techniques.

1710 5.8.7 [RQ-AVAIL-007]

1711 **Requirement:** The boot manager shall ensure availability of essential boot code in the presence of storage corruption or
 1712 failure.

1713 **Applicability:** Applies to MEDIUM and HIGH risk boot managers that are not written in immutable memory.

1714 NOTE 1: Mechanisms to ensure availability may include redundant storage of essential boot code or fallback boot
 1715 partitions.

1716 NOTE 2: Essential boot code includes components required to initialize the platform and load subsequent boot
 1717 stages.

1718 5.8.8 [RQ-AVAIL-008]

1719 **Requirement:** The boot manager shall require authentication or physical presence before performing sensitive actions
 1720 in recovery mode.

1721 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with recovery capability.

1722 NOTE: Recovery mode may be triggered automatically upon boot failures; however, any critical or security-
 1723 relevant operations performed during recovery mode require authentication or physical presence,

1724 5.8.9 [RQ-AVAIL-009]

1725 **Requirement:** When network boot is supported, the boot manager shall handle network boot failures in a manner that
 1726 maintains boot availability.

1727 **Applicability:** Applies to all boot managers with network boot.

1728 NOTE: Mechanisms for handling network boot failures may include: a) enforcing timeouts; b) falling back to a
 1729 local boot mechanism; c) performing exponential backoff retries; d) attempting multiple authorized
 1730 network boot servers.

1731 5.8.10 [RQ-AVAIL-010]

1732 **Requirement:** When network boot is supported, the boot manager shall maintain local boot capability when network
1733 services are unavailable or under denial-of-service conditions.

1734 **Applicability:** Applies to all boot managers with network boot.

1735 5.8.11 [RQ-AVAIL-011]

1736 **Requirement:** The boot manager shall generate logs for security-relevant failure conditions.

1737 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with verified boot or measured boot and logging
1738 capability.

1739 NOTE: Security-relevant failure conditions may include verification failures, integrity violations, authentication
1740 failures, or unexpected modification of boot components

1741 5.8.12 [RQ-AVAIL-012]

1742 **Requirement:** The boot manager shall protect security-relevant logs against tampering.

1743 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with verified boot or measured boot and logging
1744 capability.

1745 5.8.13 [RQ-AVAIL-013]

1746 **Requirement:** The boot manager shall use time representations that remain valid beyond 2038.

1747 **Applicability:** Applies to all boot managers.

1748 NOTE 1: This requirement applies to all security-relevant uses of time, including:

- 1749 a) certificate validity periods;
- 1750 b) internal system time used for boot decisions;
- 1751 c) timestamps recorded in logs or audit records.

1752 NOTE 2: This requirement helps prevent failures associated with 32-bit time representations (commonly known as
1753 the Year-2038 problem).

1754 5.8.14 [RQ-AVAIL-014]

1755 **Requirement:** The boot manager shall protect recovery mechanisms from unauthorized modification or disablement.

1756 **Applicability:** Applies to all boot managers with recovery capability.

1757 5.8.15 [RQ-AVAIL-015]

1758 **Requirement:** The boot manager shall prevent partial execution of boot components when verification has not
1759 completed successfully.

1760 **Applicability:** Applies to all boot managers.

1761 5.8.16 [RQ-AVAIL-016]

1762 **Requirement:** The boot manager shall not perform security-sensitive operations when required cryptographic
1763 components or services are unavailable.

1764 **Applicability:** Applies to all boot managers.

1765 5.8.17 [RQ-AVAIL-017]

1766 **Requirement:** The boot manager shall not bypass security controls when handling security violations or verification
1767 failures.

1768 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with recovery capability.

1769 5.8.18 [RQ-AVAIL-018]

1770 **Requirement:** The boot manager shall preserve recovery capability across firmware or configuration updates.
 1771 **Applicability:** Applies to all boot managers with update and recovery capabilities.

1772 5.9 Impact Minimization

1773 5.9.0 Introduction to impact minimization requirements

1774 This clause addresses CRA requirements for impact minimization on other systems. Boot managers shall limit resource
 1775 consumption, release hardware properly, and prevent cascading failures to connected devices or networks.

1776 5.9.1 [RQ-IMPACT-001]

1777 **Requirement:** The boot manager shall avoid generating harmful or disruptive network behaviour.
 1778 **Applicability:** Applies to all boot managers with network boot.

1779 NOTE: Examples of harmful or disruptive network behaviour include: a) broadcast storms; b) network loops.

1780 5.10 Attack Surface Minimization

1781 5.10.0 Introduction to attack surface minimization

1782 This clause addresses CRA requirements for attack surface minimization by limiting functionality, eliminating debug
 1783 interfaces, and restricting all non-essential capabilities in production builds.

1784 5.10.1 [RQ-SURFACE-001]

1785 **Requirement:** The boot manager shall exclude non-essential code from production builds.
 1786 **Applicability:** Applies to all boot managers.

1787 NOTE: Examples for exclude non-essential code may include test code, debug instrumentation, coverage tools,
 1788 experimental features, and unsupported platform code.

1789 5.10.2 [RQ-SURFACE-002]

1790 **Requirement:** The boot manager shall disable or protect interfaces and functions that are not intended for operational
 1791 use.
 1792 **Applicability:** Applies to all boot managers.

1793 NOTE: Examples of interfaces and functions that should be disabled in production configuration include: a)
 1794 debug interfaces; b) diagnostic consoles; c) test or manufacturing modes; d) verbose or developer-
 1795 oriented logging.

1796 5.10.3 [RQ-SURFACE-003]

1797 **Requirement:** The boot manager shall remove unused or non-essential interfaces and protocols to reduce the attack
 1798 surface.
 1799 **Applicability:** Applies to all boot managers.

1800 NOTE: Examples of interfaces and protocols that should be disabled include: a) unused hardware interfaces; b)
 1801 legacy or deprecated protocols; c) non-essential network services or discovery mechanisms.

1802 5.10.4 [RQ-SURFACE-004]

1803 **Requirement:** The boot manager shall validate all inputs to ensure they conform to expected formats.
 1804 **Applicability:** Applies to all boot managers.

NOTE 1: Input validation mechanisms may include:

- a) bounds checking;
- b) enforcement of size limits;
- c) rejection of malformed, truncated, or oversized data.

NOTE 2: Inputs in this context may include:

- a) boot images;
- b) certificates;
- c) configuration;
- d) cryptographic data before processing.

5.10.5 [RQ-SURFACE-005]

Requirement: The boot manager shall detect errors in critical operations and reject non-compliant inputs; transition to error handling on faults.

Applicability: Applies to all boot managers with network boot.

5.10.6 [RQ-SURFACE-006]

Requirement: The boot manager shall protect configuration data by detecting unauthorized modifications.

Applicability: Applies to all boot managers with configuration capability.

5.10.7 [RQ-SURFACE-007]

Requirement: The boot manager shall limit configuration options to essential parameters required for normal operations.

Applicability: Applies to all boot managers with configuration capability.

5.11 Logging and Monitoring

5.11.0 Introduction to logging and monitoring requirements

This clause addresses CRA requirements for security monitoring. Boot managers provide visibility into boot processes through logs and attestation within pre-OS constraints of limited storage and no file systems.

5.11.1 [RQ-LOG-001]

Requirement: The boot manager shall record measurements of boot components and security-critical configuration in tamper-resistant storage before execution or handoff.

Applicability: Applies to all boot managers with verified or measured boot and logging capability.

5.11.2 [RQ-LOG-002]

Requirement: The boot manager shall protect measurement records from unauthorized modification or deletion using cryptographic mechanisms, hardware-protected storage, or tamper-evident recording.

Applicability: Applies to all boot managers with verified or measured boot and logging capability.

5.11.3 [RQ-LOG-003]

Requirement: The boot manager shall provide measurement records in a format that supports remote attestation and includes mechanisms to ensure freshness against replay.

Applicability: Applies to MEDIUM and HIGH risk boot managers with measured boot and logging capability.

NOTE 1: Freshness mechanisms may include nonces, monotonic counters, timestamps, or challenge-response protocols.

NOTE 2: Measurement records may include information such as:

- a) integrity digests of boot components;
- b) indices or identifiers of measured registers or structures;
- c) event types or measurement categories;
- d) version or revision information of components.

5.11.4 [RQ-LOG-004]

Requirement: The boot manager shall indicate security-relevant failures and state changes.

Applicability: Applies to all boot managers with logging capability.

NOTE: Examples security-relevant failures and state changes includes:

- a) verification failures;
- b) authentication failures;
- c) security policy violations;
- d) recovery mode activation;
- e) execution of unsigned code.

5.11.5 [RQ-LOG-005]

Requirement: The boot manager shall protect integrity of measurement records during transmission to external verifiers.

Applicability: Applies to all boot managers with measured boot.

5.12 Vulnerability Management

5.12.0 Introduction to vulnerability management requirements

This clause addresses CRA requirements for vulnerability management. Boot managers shall support secure updates throughout product lifecycle, or clearly document limitations and compensating controls for non-updateable implementations.

5.12.1 [RQ-VULN-001]

Requirement: The boot manager shall provide version information accessible to operating system, management systems or authorized entity.

Applicability: Applies to all boot managers.

5.12.2 [RQ-VULN-002]

Requirement: Where a user interface is available, the boot manager shall provide status indicators for available updates or rely on authorized components to present such indicators.

Applicability: Applies to MEDIUM and HIGH risk boot managers with update and configuration capabilities.

NOTE: Authorized components may include the operating system, firmware management services, or other trusted update-management mechanisms.

1876 5.12.3 [RQ-VULN-003]

1877 **Requirement:** When network capability is available, the boot manager shall support mechanisms to check for the
1878 availability of updates.

1879 **Applicability:** Applies to MEDIUM and HIGH risk boot managers with update capability.

1880 5.12.4 [RQ-VULN-004]

1881 **Requirement:** The boot manager shall implement defence-in-depth by using multiple, independent security
1882 mechanisms to protect the boot process.

1883 **Applicability:** Applies to all boot managers without update capability.

1884 NOTE: Examples of independent security mechanisms include:

1885 a) memory protection or access-control enforcement;

1886 b) input validation and data-format verification;

1887 c) hardware-based isolation or separation;

1888 d) cryptographic verification of components.

1889 5.12.5 [RQ-VULN-005]

1890 **Requirement:** The boot manager shall enable security policy updates through configuration, allow disabling features to
1891 address vulnerabilities, and maintain configuration update capability throughout product lifetime.

1892 **Applicability:** Applies to all boot managers with configuration capability.

1893 5.12.6 [RQ-VULN-006]

1894 **Requirement:** The boot manager shall verify updates before committing them to the system.

1895 **Applicability:** Applies to all boot managers with update capability.

1896 NOTE 1: Verification may include integrity checks, authenticity checks, and policy compliance validation.

1897 NOTE 2: Committing an update includes writing updated images, configuration, or metadata to persistent storage.

1898 5.12.7 [RQ-VULN-007]

1899 **Requirement:** The boot manager shall accept updates only from authenticated and authorized sources.

1900 **Applicability:** Applies to all boot managers with update capability.

1901 5.12.8 [RQ-VULN-008]

1902 **Requirement:** When hardware security components are available, the boot manager shall store update-verification keys
1903 using those components.

1904 **Applicability:** Applies to all boot managers with update capability.

1905 5.12.9 [RQ-VULN-009]

1906 **Requirement:** The boot manager shall isolate update logic from normal boot path.

1907 **Applicability:** Applies to all boot managers with update capability.

1908 5.13 Security Testing and Review

1909 Security testing requirements are addressed through conformity assessment procedures in clause 6 and documentation
1910 requirements in Annex C.

6 Conformity assessment and testing

6.1 General

6.1.1 Assessment principles

This clause defines assessment criteria for requirements in clause 5.

Assessments shall be:

- **Objective:** Repeatable with consistent results regardless of assessor.
- **Evidence-based:** Verdicts supported by documented evidence.
- **Risk-proportionate:** Assessment depth corresponds to declared risk level.
- **Configuration-aware:** Scope determined by product capabilities.
- **Threat-traceable:** Criteria address applicable threats per Annex B.

NOTE: Confidential information handling follows Regulation (EU) 2024/2847 [i.1], Article 57.

6.1.2 Assessment structure

Each assessment specifies:

- **Assessment reference:** Requirement identifiers and applicable risk levels.
- **Objective:** Security property being verified.
- **Pass criteria:** Observable outcomes demonstrating conformity, organized by risk level.
- **Evidence:** Documentation and artefacts supporting the verdict.

6.1.3 Verdicts

Assessments result in one of four verdicts:

Table 6.1.3-1: Assessment result in one of four verdicts

Verdict	Meaning
PASS	All applicable pass criteria satisfied for declared risk level
FAIL	One or more applicable pass criteria not satisfied
INCONCLUSIVE	Insufficient evidence to determine pass or fail
NOT APPLICABLE	Requirement does not apply based on capabilities; justification required

Overall conformity requires PASS or NOT APPLICABLE for all requirements at the declared risk level.

6.1.4 Risk level and assessment depth

Assessment depth scales with risk level determined per clause 4.7.8:

Table 6.1.4-1: Risk level and assessment depth

Risk Level	Assessment Depth
LOW	Documentation review, basic functional verification
MEDIUM	LOW + security mechanism testing, failure mode verification
HIGH	MEDIUM + resistance testing, protection bypass attempts

Pass criteria are cumulative: HIGH risk requires satisfying LOW, MEDIUM, and HIGH criteria.

6.1.5 Boot manager assessment considerations

Boot manager assessment may require:

- Platform-specific test environments due to hardware dependency.
- Specialized access to pre-OS execution environment.
- System integration context for component-level products.
- Physical access to hardware interfaces.

Manufacturers shall document the test environment and any platform-specific limitations affecting assessment.

6.1.6 Component vs product assessment

When boot managers are provided as components:

- Component assessment addresses standalone functionality.
- Integration requirements shall be documented.
- System integrator assesses integrated behaviour.
- Documentation shall indicate assessment boundaries.

6.1.7 Assessment report requirements

Reports shall include:

- Product identification and configuration.
- Use case and risk level determination per clause 4.7.
- Requirement applicability with justification for NOT APPLICABLE verdicts.
- Pass criteria evaluation and verdict for each assessment.
- Evidence references.
- Overall conformity statement.

1959 6.2 EA-BM-DESIGN: Secure design

1960 6.2.1 Assessment reference

1961 **Table 6.2.1-1: Requirements risk assesement**

Requirement	Description	Applicable Risk
RQ-SBD-001	Isolate boot components using memory protection or privilege separation	ALL
RQ-SBD-002	Restrict access to cryptographic key material to authorized components	ALL
RQ-SBD-003	Disable debug interfaces and release resources before boot target handoff	ALL
RQ-SBD-004	Enforce privilege boundaries between boot stages	ALL
RQ-SBD-005	Use device-specific keys for symmetric verified/measured boot	ALL
RQ-SURFACE-001	Exclude non-essential code from production builds	ALL
RQ-SURFACE-002	Disable interfaces not required for intended functionality	ALL
RQ-SURFACE-003	Disable unused or non-essential interfaces	ALL
RQ-SURFACE-004	Validate all inputs for conformance to expected formats	ALL
RQ-SURFACE-005	Detect errors in critical operations and handle gracefully	ALL
RQ-SURFACE-006	Protect configuration by detecting unauthorized modifications	ALL
RQ-SURFACE-007	Limit configuration options to functionally required settings	ALL

1962

1963 6.2.2 Objective

1964 Verify that the boot manager implements secure design principles including component isolation, privilege separation,
1965 attack surface minimization, and input validation.

1966 6.2.3 Pass criteria

1967 6.2.3.1 Component isolation

1968 **Requirements:** RQ-SBD-001, RQ-SBD-004

1969 **Table 6.2.3.1-1: Component isolation**

Risk	Pass Criteria
LOW	Isolation mechanisms documented; privilege boundaries defined
MEDIUM	Attempted privilege escalation between boot stages denied
HIGH	Isolation bypass attempts unsuccessful

1970

1971 **Fail indicators:** Undocumented privilege boundaries, cross-stage privilege escalation possible.

1972 6.2.3.2 Key material protection

1973 **Requirements:** RQ-SBD-002, RQ-SBD-005

1974 **Table 6.2.3.2-1: Key material protection**

Risk	Pass Criteria
LOW	Key access restrictions documented; device-specific keys used for symmetric operations
MEDIUM	Unauthorized key access denied
HIGH	Key extraction attempts unsuccessful

1975

1976 **Fail indicators:** Global symmetric keys used, key material accessible to unauthorized components.

6.2.3.3 Handoff security

Requirements: RQ-SBD-003

Table 6.2.3.3-1: handoff security

Risk	Pass Criteria
LOW	Handoff procedure documented; resource cleanup specified
MEDIUM	Debug interfaces disabled after handoff; DMA access revoked
HIGH	Post-handoff resource access attempts unsuccessful

Fail indicators: Debug interfaces remain enabled, sensitive memory accessible after handoff.

6.2.3.4 Attack surface minimization

Requirements: RQ-SURFACE-001 to RQ-SURFACE-005

Table 6.2.3.4-1: Attack surface minimization

Risk	Pass Criteria
LOW	Non-essential code excluded; debug interfaces disabled in production
MEDIUM	Unused interfaces verified disabled; debug activation requires authentication
HIGH	Interface re-enablement attempts unsuccessful without authorization

Fail indicators: Test code in production build, unauthenticated debug access possible.

6.2.3.5 Input validation

Requirements: RQ-SURFACE-004 to RQ-SURFACE-007

Table 6.2.3.5-1: Input validation

Risk	Pass Criteria
LOW	Input validation documented; bounds checking implemented
MEDIUM	Malformed inputs rejected; oversized data rejected
HIGH	Input fuzzing produces no exploitable failures

Fail indicators: Buffer overflows possible, malformed data accepted.

6.2.4 Evidence

Table 6.2.4-1: Evidence

Evidence	LOW	MEDIUM	HIGH
Security architecture documentation	X	X	X
Isolation mechanism specification	X	X	X
Privilege escalation test results	–	X	X
Debug interface state verification	X	X	X
Input validation test results	–	X	X
Fuzzing results	–	–	X

6.3 EA-BM-DEFAULT: Secure defaults

6.3.1 Assessment reference

Table 6.3.1-1: Assessment reference

Requirement	Description	Applicable Risk
RQ-DEFAULT-001	Enable cryptographic validation by default	ALL
RQ-DEFAULT-002	Do not implement undocumented security bypass mechanisms	ALL
RQ-DEFAULT-003	Require credentials to be established during initial deployment	ALL
RQ-DEFAULT-004	Prevent automatic fallback to less secure boot modes	ALL
RQ-DEFAULT-005	Indicate when security-relevant settings differ from defaults	ALL
RQ-DEFAULT-006	Support restoring secure default configuration settings	ALL
RQ-MINIMAL-001	Minimize disclosure of information during boot	ALL
RQ-MINIMAL-002	Prevent disclosure of sensitive data during network operations	ALL
RQ-MINIMAL-003	Limit console output to essential operational messages	ALL

6.3.2 Objective

Verify that the boot manager ships with secure default configuration, minimizes data exposure, and supports restoration of secure state.

6.3.3 Pass criteria

6.3.3.1 Secure default state

Requirements: RQ-DEFAULT-001, RQ-DEFAULT-002

Table 6.3.3.1-1: Pass criteria

Risk	Pass Criteria
LOW	Signature validation enabled by default; no default passwords
MEDIUM	Secure defaults verified functional after reset
HIGH	Default bypass attempts unsuccessful

Fail indicators: Signature validation disabled by default, default credentials present, undocumented access methods.

6.3.3.2 Fallback prevention

Requirements: RQ-DEFAULT-004, RQ-DEFAULT-005

Table 6.3.3.2-1: Fallback prevention

Risk	Pass Criteria
LOW	Automatic fallback to insecure modes prevented; security reduction indicated
MEDIUM	Forced fallback attempts rejected
HIGH	Fallback bypass attempts unsuccessful

2012 **Fail indicators:** Automatic fallback to unsigned boot, security reduction not indicated.

2013 6.3.3.3 Secure state restoration

2014 **Requirements:** RQ-DEFAULT-003, RQ-DEFAULT-006

2015 **Table 6.3.3.3-1: Secure state restoration**

Risk	Pass Criteria
LOW	Factory reset restores secure defaults; credentials established during deployment
MEDIUM	Reset procedure verified functional
HIGH	Partial reset cannot leave insecure state

2016

2017 **Fail indicators:** Reset leaves insecure configuration, pre-set credentials persist.

2018 6.3.3.4 Data minimization

2019 **Requirements:** RQ-MINIMAL-001 to RQ-MINIMAL-003

2020 **Table 6.3.3.4-1: Data minimization**

Risk	Pass Criteria
LOW	Only essential data stored and transmitted
MEDIUM	Network protocols disclose only MAC address and device class
HIGH	Information leakage analysis shows no sensitive data exposure

2021

2022 **Fail indicators:** Firmware version disclosed in network protocols, unnecessary data retained.

2023 6.3.4 Evidence

2024 **Table 6.3.4-1: Evidence**

Evidence	LOW	MEDIUM	HIGH
Default configuration documentation	X	X	X
Factory reset test results	X	X	X
Network protocol analysis	–	X	X
Information leakage assessment	–	–	X

2025

2026 6.4 EA-BM-AUTH: Authentication and access control

2027 6.4.1 Assessment reference

2028 **Table 6.4.1-1: Assessment reference**

Requirement	Description	Applicable Risk
RQ-AUTH-001	Require physical presence or signed artefact for trust anchor changes	ALL
RQ-AUTH-002	Protect boot configuration settings against unauthorized modification	ALL
RQ-AUTH-003	Require explicit action and authentication for security changes	ALL
RQ-AUTH-004	Limit authentication attempts and support lockout mechanisms	ALL
RQ-AUTH-005	Verify authenticity and integrity of security policy updates	ALL
RQ-AUTH-006	Indicate when operating with modified security configuration	ALL
RQ-AUTH-007	Protect trusted certificate stores from unauthorized modification	ALL

2029

2030 6.4.2 Objective

2031 Verify that the boot manager implements appropriate authentication and access controls for security-relevant
2032 operations.

2033 6.4.3 Pass criteria

2034 6.4.3.1 Trust anchor modification

2035 **Requirements:** RQ-AUTH-001, RQ-AUTH-007

2036 **Table 6.4.3.1-1: Pass criteria**

Risk	Pass Criteria
LOW	Trust anchor modification requires physical presence or signed artefact
MEDIUM	Remote trust anchor modification without authorization rejected
HIGH	Trust anchor bypass attempts unsuccessful

2037

2038 **Fail indicators:** Remote trust anchor modification possible without authorization.

2039 6.4.3.2 Configuration protection

2040 **Requirements:** RQ-AUTH-002, RQ-AUTH-003

2041 **Table 6.4.3.2-1: Configuration protection**

Risk	Pass Criteria
LOW	Boot order and security settings protected; explicit action required for security changes
MEDIUM	Unauthenticated configuration modification rejected
HIGH	Configuration protection bypass attempts unsuccessful

2042

2043 **Fail indicators:** Boot order changeable without authentication, security settings modifiable without authorization.

2044 6.4.3.3 Authentication mechanisms

2045 **Requirements:** RQ-AUTH-004, RQ-AUTH-005

2046 **Table 6.4.3.3-1: Authentication mechanisms**

Risk	Pass Criteria
LOW	Rate limiting on failed attempts; policy signatures verified
MEDIUM	Brute force attack mitigated by delays; invalid signatures rejected
HIGH	Authentication mechanism bypass attempts unsuccessful

2047

2048 **Fail indicators:** Unlimited authentication attempts, unsigned policies accepted.

2049 6.4.3.4 Policy indication

2050 **Requirements:** RQ-AUTH-006

2051 **Table 6.4.3.4-1: Policy indication**

Risk	Pass Criteria
LOW	Modified policy indicated through visual or logged indication
MEDIUM	Indication mechanism verified functional
HIGH	Indication cannot be suppressed

2052

2053 **Fail indicators:** Modified policy not indicated, indication bypassable.

2054 6.4.4 Evidence

2055 **Table 6.4.4-1: Evidence**

Evidence	LOW	MEDIUM	HIGH
Authentication mechanism documentation	X	X	X
Physical presence requirement verification	X	X	X
Rate limiting test results	–	X	X
Bypass attempt results	–	–	X

2056

2057 6.5 EA-BM-CONFID: Confidentiality

2058 6.5.1 Assessment reference

2059 **Table 6.5.1-1: Assessment reference**

Requirement	Description	Applicable Risk
RQ-CONFID-001	Ensure cryptographic key separation for different functions	ALL
RQ-CONFID-002	Prevent sensitive data from appearing in crash dumps or logs	ALL
RQ-CONFID-003	Protect stored credentials using approved mechanisms	ALL
RQ-CONFID-004	Protect credentials transmitted over network connections	ALL
RQ-CONFID-005	Cryptographically erase sensitive data during secure disposal	ALL
RQ-CONFID-006	Indicate successful completion of secure disposal	ALL
RQ-CONFID-007	Protect confidentiality of boot configuration over network	ALL

2060

2061 6.5.2 Objective

2062 Verify that the boot manager protects confidentiality of sensitive data including cryptographic keys, credentials, and
2063 configuration.

2064 6.5.3 Pass criteria

2065 6.5.3.1 Key separation

2066 **Requirements:** RQ-CONFID-001

2067 **Table 6.5.3.1-1: Key separation**

Risk	Pass Criteria
LOW	Separate keys for verification, encryption, and decryption documented
MEDIUM	Key separation verified in implementation
HIGH	Key confusion attacks unsuccessful

2068

2069 **Fail indicators:** Same key used for multiple purposes.

2070 6.5.3.2 Sensitive data protection

2071 **Requirements:** RQ-CONFID-002, RQ-CONFID-003, RQ-CONFID-006, RQ-CONFID-008

2072 **Table 6.5.3.2-1: Sensitive data protection**

Risk	Pass Criteria
LOW	Sensitive data excluded from logs; keys masked in output
MEDIUM	Crash dumps contain no sensitive data; temporary data cleared
HIGH	Memory analysis reveals no sensitive data after clearance

2073

2074 **Fail indicators:** Keys appear in logs, sensitive data in crash dumps.

2075 6.5.3.3 Credential storage

2076 **Requirements:** RQ-CONFID-004

2077 **Table 6.5.3.3-1: Credential storage**

Risk	Pass Criteria
LOW	Credentials stored using approved protection mechanisms
MEDIUM	Credential extraction denied
HIGH	Credential recovery attacks unsuccessful

2078

2079 **Fail indicators:** Plaintext credential storage, credentials extractable.

2080 6.5.3.4 Network confidentiality

2081 **Requirements:** RQ-CONFID-005, RQ-CONFID-007

2082 **Table 6.5.3.4-1: Network confidentiality**

Risk	Pass Criteria
LOW	Network boot parameters encrypted
MEDIUM	Network traffic analysis reveals no credentials
HIGH	Man-in-the-middle attacks unsuccessful

2083

2084 **Fail indicators:** Credentials transmitted in cleartext.

2085 **Applicability:** Applies to boot managers with network boot capability.

2086 6.5.3.5 Secure disposal

2087 **Requirements:** RQ-CONFID-007, RQ-CONFID-008

2088 **Table 6.5.3.5-1: Secure disposal**

Risk	Pass Criteria
LOW	Cryptographic erasure documented; completion indicated
MEDIUM	Post-disposal data recovery unsuccessful
HIGH	Forensic recovery attempts unsuccessful

2089

2090 **Fail indicators:** Data recoverable after disposal, no completion indication.

2091 6.5.4 Evidence

2092 **Table 6.5.4-1: Evidence**

Evidence	LOW	MEDIUM	HIGH
Key management documentation	X	X	X
Log sanitization verification	X	X	X
Credential storage analysis	–	X	X
Network traffic analysis	–	X	X
Post-disposal recovery test	–	X	X

2093

2094 6.6 EA-BM-INTEGRITY: Integrity protection

2095 6.6.1 Assessment reference

2096 **Table 6.6.1-1: Assessment reference**

Requirement	Description	Applicable Risk
RQ-INTEGRITY-001	Verify integrity and authenticity of each boot stage	ALL
RQ-INTEGRITY-002	Prevent boot continuation when verification fails	ALL
RQ-INTEGRITY-003	Verify component provenance and compatibility	ALL
RQ-INTEGRITY-004	Verify update packages before installation	ALL
RQ-INTEGRITY-005	Detect unauthorized firmware modifications	ALL
RQ-INTEGRITY-006	Verify software-based cryptographic verification	ALL
RQ-INTEGRITY-007	Maintain configurable list of approved boot components	ALL
RQ-INTEGRITY-008	Support hardware security modules for key operations	MEDIUM+
RQ-INTEGRITY-009	Require authentication for modifying approved component list	MEDIUM+
RQ-INTEGRITY-010	Prevent modification between verification and execution	ALL
RQ-INTEGRITY-011	Load components into protected memory before verification	ALL
RQ-INTEGRITY-012	Protect configuration integrity with authenticated encryption	MEDIUM+
RQ-INTEGRITY-013	Restore secure defaults when configuration corrupted	ALL
RQ-INTEGRITY-014	Authenticate network boot servers	ALL
RQ-INTEGRITY-015	Reject network boot from servers with invalid certificates	MEDIUM+
RQ-INTEGRITY-016	Verify network configuration data integrity	ALL
RQ-INTEGRITY-017	Enforce anti-rollback protection	MEDIUM+
RQ-INTEGRITY-018	Store anti-rollback counters in tamper-evident storage	HIGH
RQ-INTEGRITY-019	Verify certificate chains to trusted root	ALL
RQ-INTEGRITY-020	Support revocation of compromised components	ALL
RQ-INTEGRITY-021	Use cryptographic algorithms per ECCG recommendations	ALL
RQ-INTEGRITY-022	Support cryptographic algorithm updates	MEDIUM+
RQ-INTEGRITY-023	Use collision-resistant hashes for authentication	ALL

2097

2098 6.6.2 Objective

2099 Verify that the boot manager implements integrity protection throughout the boot chain including verification,
2100 anti-rollback, and cryptographic mechanisms.

2101 6.6.3 Pass criteria

2102 6.6.3.1 Chain of trust

2103 **Requirements:** RQ-INTEGRITY-001, RQ-INTEGRITY-002, RQ-INTEGRITY-003

2104 **Table 6.6.3.1-1: Chain of trust**

Risk	Pass Criteria
LOW	Chain of trust documented; modified components detected
MEDIUM	Boot prevented with tampered component; provenance verified
HIGH	Chain of trust bypass attempts unsuccessful

2105

2106 **Fail indicators:** Unsigned component executed, chain not rooted in hardware.

2107 6.6.3.2 Cryptographic mechanisms

2108 **Requirements:** RQ-INTEGRITY-005, RQ-INTEGRITY-021, RQ-INTEGRITY-023

2109 **Table 6.6.3.2-1: Cryptographic mechanisms**

Risk	Pass Criteria
LOW	Approved algorithms used per ECCG; collision-resistant hashes for authentication
MEDIUM	Defence-in-depth verification implemented; algorithm configuration documented
HIGH	Cryptographic attack attempts unsuccessful; algorithm substitution prevented

2110

2111 **Fail indicators:** Non-approved algorithms, single verification mechanism at MEDIUM+.

2112 6.6.3.3 Verification integrity

2113 **Requirements:** RQ-INTEGRITY-009, RQ-INTEGRITY-010

2114 **Table 6.6.3.3-1: Verification integrity**

Risk	Pass Criteria
LOW	TOCTOU prevention documented; protected memory used
MEDIUM	Verification executes atomically
HIGH	TOCTOU exploitation attempts unsuccessful

2115

2116 **Fail indicators:** Exploitable TOCTOU window, verification in unprotected memory.

2117 6.6.3.4 Configuration integrity

2118 **Requirements:** RQ-INTEGRITY-012, RQ-INTEGRITY-013, RQ-INTEGRITY-014

2119 **Table 6.6.3.4-1: Configuration integrity**

Risk	Pass Criteria
LOW	Configuration corruption detected; secure defaults restored
MEDIUM	Configuration protected with authenticated encryption
HIGH	Runtime modification attempts unsuccessful

2120

2121 **Fail indicators:** Corruption undetected, unauthenticated configuration accepted at MEDIUM+.

2122 **Applicability:** Applies at MEDIUM+ for RQ-INTEGRITY-012.

2123 6.6.3.5 Network boot integrity

2124 **Requirements:** RQ-INTEGRITY-015, RQ-INTEGRITY-016, RQ-INTEGRITY-017

2125 **Table 6.6.3.5-1: Network boot integrity**

Risk	Pass Criteria
LOW	Network boot server verification documented
MEDIUM	Server authenticated with certificates; invalid certificates rejected
HIGH	DHCP/PXE spoofing attacks unsuccessful

2126

2127 **Fail indicators:** Unauthenticated network boot server accepted.

2128 **Applicability:** Applies to boot managers with network boot capability.

2129 6.6.3.6 Anti-rollback

2130 **Requirements:** RQ-INTEGRITY-018, RQ-INTEGRITY-019

2131 **Table 6.6.3.6-1: Anti-rollback**

Risk	Pass Criteria
MEDIUM	Rollback to previous version prevented or detected
HIGH	Anti-rollback counters in tamper-evident storage; counter manipulation unsuccessful

2132

2133 **Fail indicators:** Rollback successful, counter bypassable.

2134 **Applicability:** Applies at MEDIUM+ for RQ-INTEGRITY-018, HIGH for RQ-INTEGRITY-019.

2135 6.6.3.7 Trust hierarchy

2136 **Requirements:** RQ-INTEGRITY-020, RQ-INTEGRITY-021, RQ-INTEGRITY-022

2137 **Table 6.6.3.7-1: Trust hierarchy**

Risk	Pass Criteria
LOW	Certificate chain verification documented; revocation mechanism specified
MEDIUM	Chain verification and revocation verified functional
HIGH	Trust hierarchy manipulation attempts unsuccessful

2138

2139 **Fail indicators:** Incomplete chain verification, no revocation support.

2140 6.6.3.8 Cryptographic agility

2141 **Requirements:** RQ-INTEGRITY-022

2142 **Table 6.6.3.8-1: Cryptographic agility**

Risk	Pass Criteria
MEDIUM	Algorithm update mechanism documented; transition procedure specified
HIGH	Algorithm transition verified functional; downgrade to deprecated algorithms prevented

2143

2144 **Fail indicators:** No algorithm update capability.

2145 **Applicability:** Applies at MEDIUM+.

2146 6.6.4 Evidence

2147 **Table 6.6.4-1: Evidence**

Evidence	LOW	MEDIUM	HIGH
Chain of trust documentation	X	X	X
Cryptographic mechanism specification	X	X	X
Component modification test results	X	X	X
TOCTOU analysis	–	X	X
Rollback test results	–	X	X
Certificate validation test results	X	X	X
Bypass attempt results	–	–	X

2148

2149 6.7 EA-BM-AVAIL: Availability and resilience

2150 6.7.1 Assessment reference

2151 **Table 6.7.1-1: Assessment reference**

Requirement	Description	Applicable Risk
RQ-AVAIL-001	Support fallback to previous known-good configuration	ALL
RQ-AVAIL-002	Support redundant boot paths	MEDIUM+
RQ-AVAIL-003	Enforce timeouts to prevent indefinite blocking	ALL
RQ-AVAIL-004	Limit retry attempts with delay escalation	ALL
RQ-AVAIL-005	Prevent skipping security verification steps	ALL
RQ-AVAIL-006	Detect and correct errors in boot-critical data	MEDIUM+
RQ-AVAIL-007	Ensure availability of essential boot code	MEDIUM+
RQ-AVAIL-008	Performing sensitive actions in recovery mode	ALL
RQ-AVAIL-009	Handle network boot failures	ALL
RQ-AVAIL-010	Maintain local boot capability	ALL
RQ-AVAIL-011	Generate logs for security-relevant failure conditions	MEDIUM+
RQ-AVAIL-012	Protect security-relevant logs against tampering	MEDIUM+
RQ-AVAIL-013	Use time representations valid beyond year 2038	ALL
RQ-AVAIL-014	Protect recovery partition integrity	ALL
RQ-AVAIL-015	Prevent partial execution of components	ALL
RQ-AVAIL-016	Perform security-sensitive operations with required cryptographic components or services	ALL
RQ-AVAIL-017	Require authentication for recovery mode	MEDIUM+
RQ-AVAIL-018	Preserve recovery capabilities during updates	ALL

2152

2153 6.7.2 Objective

2154 Verify that the boot manager maintains availability through failure recovery, redundancy, and resilience mechanisms.

2155 6.7.3 Pass criteria

2156 6.7.3.1 Configuration recovery

2157 **Requirements:** RQ-AVAIL-001, RQ-AVAIL-002

2158 **Table 6.7.3.1-1: Configuration recovery**

Risk	Pass Criteria
LOW	Fallback to known-good configuration supported; corruption recovery documented
MEDIUM	Recovery verified functional
HIGH	Recovery cannot be prevented by attacker action

2159

2160 **Fail indicators:** No fallback capability, corruption causes permanent failure.

2161 6.7.3.2 Redundancy

2162 **Requirements:** RQ-AVAIL-003, RQ-AVAIL-004, RQ-AVAIL-009

2163 **Table 6.7.3.2-1: Redundancy**

Risk	Pass Criteria
MEDIUM	Redundant boot path verified functional; active image indicated
HIGH	Single storage failure does not prevent boot

2164

2165 **Fail indicators:** No redundant boot path at MEDIUM+.

2166 **Applicability:** Applies at MEDIUM+.

2167 6.7.3.3 Resource limits

2168 **Requirements:** RQ-AVAIL-005, RQ-AVAIL-006

2169 **Table 6.7.3.3-1: Resource limits**

Risk	Pass Criteria
LOW	Timeouts enforced; retry limits documented
MEDIUM	Indefinite hang prevented; resource exhaustion prevented
HIGH	Denial-of-service attacks mitigated

2170

2171 **Fail indicators:** Operations can hang indefinitely, unlimited retries.

2172 6.7.3.4 Security verification integrity

2173 **Requirements:** RQ-AVAIL-007

2174 **Table 6.7.3.4-1: Security verification integrity**

Risk	Pass Criteria
LOW	Verification steps cannot be skipped; checksums verified
MEDIUM	Skip attempts rejected
HIGH	Verification bypass attempts unsuccessful

2175

2176 **Fail indicators:** Security steps skippable.

2177 6.7.3.5 Recovery security

2178 **Requirements:** RQ-AVAIL-011, RQ-AVAIL-015, RQ-AVAIL-017

2179 **Table 6.7.3.5-1: recovery security**

Risk	Pass Criteria
LOW	Recovery mechanisms protected
MEDIUM	Recovery requires authentication or physical presence
HIGH	Recovery security equivalent to normal boot

2180

2181 **Fail indicators:** Recovery bypasses security controls, unauthenticated recovery at MEDIUM+.

2182 **Applicability:** RQ-AVAIL-011 and RQ-AVAIL-017 apply at MEDIUM+.

2183 6.7.3.6 Failure handling

2184 **Requirements:** RQ-AVAIL-016, RQ-AVAIL-018

2185 **Table 6.7.3.6-1: Failure handling**

Risk	Pass Criteria
LOW	Boot halted on verification failure; error indicated
MEDIUM	Partial execution prevented
HIGH	Failure handling does not create exploitable state

2186

2187 **Fail indicators:** Partial boot on failure, insufficient error indication.

2188 6.7.3.7 Network resilience

2189 **Requirements:** RQ-AVAIL-009, RQ-AVAIL-010, RQ-IMPACT-001

2190 **Table 6.7.3.7-1: Network resilience**

Risk	Pass Criteria
LOW	Network failure handled with local fallback; broadcast storms avoided
MEDIUM	DoS conditions do not prevent local boot
HIGH	Network attacks cannot cause permanent failure

2191

2192 **Fail indicators:** Network failure prevents any boot, broadcast storms generated.

2193 **Applicability:** Applies to boot managers with network boot capability.

2194 6.7.3.8 Temporal validity

2195 **Requirements:** RQ-AVAIL-013

2196 **Table 6.7.3.8-1: temporal validity**

Risk	Pass Criteria
ALL	Time representations use 64-bit or equivalent range; date calculations verified for 2038-01-19 and beyond

2197

2198 **Fail indicators:** 32-bit signed timestamp overflow.

2199 6.7.4 Evidence

2200 **Table 6.7.4-1: Evidence**

Evidence	LOW	MEDIUM	HIGH
Recovery mechanism documentation	X	X	X
Timeout configuration	X	X	X
Recovery test results	X	X	X
Redundancy verification	–	X	X
DoS resistance test results	–	–	X

2201

2202 6.8 EA-BM-LOG: Logging and measurement

2203 6.8.1 Assessment reference

2204 **Table 6.8.1-1: Assessment reference**

Requirement	Description	Applicable Risk
RQ-LOG-001	Record measurements of boot components	ALL
RQ-LOG-002	Store measurements in tamper-resistant storage	ALL
RQ-LOG-003	Provide measurement records for remote attestation	MEDIUM+
RQ-LOG-004	Log security failures and state changes	ALL
RQ-LOG-005	Protect measurement confidentiality during transmission	ALL

2205

2206 6.8.2 Objective

2207 Verify that the boot manager implements security logging and measurement capabilities supporting audit and
2208 attestation.

2209 6.8.3 Pass criteria

2210 6.8.3.1 Boot measurement

2211 **Requirements:** RQ-LOG-001, RQ-LOG-002

2212 **Table 6.8.3.1-1: Boot measurement**

Risk	Pass Criteria
LOW	Boot components measured; measurements stored in tamper-resistant storage
MEDIUM	Measurement integrity protected
HIGH	Measurement tampering attempts unsuccessful

2213

2214 **Fail indicators:** Components not measured, measurements in unprotected storage.

2215 **Applicability:** Applies to boot managers with measured boot capability.

2216 6.8.3.2 Attestation support

2217 **Requirements:** RQ-LOG-003, RQ-LOG-005

2218 **Table 6.8.3.2-1: Attestation support**

Risk	Pass Criteria
MEDIUM	Measurement records support remote attestation; freshness mechanisms prevent replay
HIGH	Attestation forgery attempts unsuccessful; confidentiality protected during transmission

2219

2220 **Fail indicators:** Attestation replay possible, measurements forgeable.

2221 **Applicability:** Applies at MEDIUM+ for boot managers with measured boot capability.

2222 6.8.3.3 Security event logging

2223 **Requirements:** RQ-LOG-004

2224 **Table 6.8.3.3-1: Security event logging**

Risk	Pass Criteria
LOW	Security failures and state changes logged with required attributes
MEDIUM	Log integrity protected; entries include timestamps and event types
HIGH	Log tampering attempts detected; log extraction for forensics supported

2225

2226 **Fail indicators:** Security events not logged, missing log attributes.

2227 6.8.4 Evidence

2228 **Table 6.8.4-1: Assessment reference**

Evidence	LOW	MEDIUM	HIGH
Measurement mechanism documentation	X	X	X
Measurement log samples	X	X	X
Protected storage specification	X	X	X
Attestation protocol documentation	–	X	X
Log integrity verification	–	–	X

2229

2230 6.9 EA-BM-VULN: Vulnerability handling

2231 6.9.1 Assessment reference

2232 **Table 6.9.1-1: Assessment reference**

Requirement	Description	Applicable Risk
RQ-VULN-001	Provide version information to OS or management systems	ALL
RQ-VULN-002	Indicate when updates are available	ALL
RQ-VULN-003	Support network-based update checks	MEDIUM+
RQ-VULN-004	Implement defence-in-depth with multiple mechanisms	MEDIUM+
RQ-VULN-005	Support security policy updates to disable features	ALL
RQ-VULN-006	Verify updates before committing	ALL
RQ-VULN-007	Accept updates only from authenticated and authorized sources	ALL
RQ-VULN-008	Store update-verification keys	ALL
RQ-VULN-009	Isolate update logic from normal boot path	ALL

2234 6.9.2 Objective

2235 Verify that the boot manager supports vulnerability management including updates, version identification, and security
2236 policy configuration.

2237 6.9.3 Pass criteria

2238 6.9.3.1 Version identification (RQ-VULN-001)

2239 **Requirements:** RQ-VULN-001

2240 **Table 6.9.3.1-1: Version identification**

Risk	Pass Criteria
LOW	Version information accessible to OS or management systems
MEDIUM	Version reporting verified accurate
HIGH	Version information cannot be spoofed

2242 **Fail indicators:** Version information unavailable or inaccurate.

2243 6.9.3.2 Update capability

2244 **Requirements:** RQ-VULN-002, RQ-VULN-003, RQ-VULN-004

2245 **Table 6.9.3.2-1: Update capability**

Risk	Pass Criteria
LOW	Update mechanism documented; update availability indicated
MEDIUM	Update delivery verified functional; network checks supported
HIGH	Malicious update injection attempts unsuccessful

2247 **Fail indicators:** No update mechanism, no update indication at MEDIUM+.

2248 **Applicability:** RQ-VULN-003 and RQ-VULN-004 apply at MEDIUM+.

2249 6.9.3.3 Defence in depth

2250 **Requirements:** RQ-VULN-005

2251 **Table 6.9.3.3-1: Defence in depth**

Risk	Pass Criteria
LOW	At least two distinct security mechanisms implemented
MEDIUM	Mechanisms operate independently
HIGH	Single mechanism failure does not compromise security

2252

2253 **Fail indicators:** Single security mechanism only.

2254 **Applicability:** Applies to boot managers without update capability.

2255 6.9.3.4 Security policy updates

2256 **Requirements:** RQ-VULN-006

2257 **Table 6.9.3.4-1: Security policy updates**

Risk	Pass Criteria
LOW	Security policy updatable; features can be disabled
MEDIUM	Policy update verified functional throughout product lifetime
HIGH	Unauthorized policy modification attempts unsuccessful

2258

2259 **Fail indicators:** Policy not updatable, cannot disable vulnerable features.

2260 6.9.3.5 Update verification

2261 **Requirements:** RQ-VULN-007

2262 **Table 6.9.3.5-1: Update verification**

Risk	Pass Criteria
LOW	Updates verified before commit; authenticated sources only
MEDIUM	Update channel authenticated and encrypted
HIGH	Tampering during update detected

2263

2264 **Fail indicators:** Unsigned updates accepted, unauthenticated channel at MEDIUM+.

2265 6.9.3.6 Update safety

2266 **Requirements:** RQ-VULN-008, RQ-VULN-009

2267 **Table 6.9.3.6-1: Update safety**

Risk	Pass Criteria
LOW	Update operations atomic; previous version retained; update logic isolated
MEDIUM	Automatic rollback on failure
HIGH	Update failure cannot affect normal boot

2268

2269 **Fail indicators:** Partial update possible, no rollback, update affects boot path.

2270 6.9.4 Evidence

2271 Table 6.9.4-1: Evidence

Evidence	LOW	MEDIUM	HIGH
Update mechanism documentation	X	X	X
Version reporting verification	X	X	X
Update verification test results	X	X	X
Rollback test results	–	X	X
Channel security analysis	–	X	X

2272

2273

Annex A (normative): Relationship between the present document and the essential requirements of EU Regulation 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025) 618 [i.3]final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A-1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A-1: Relationship between the present document and
the requirements of Regulation (EU) No 2024/2847**

Harmonised Standard ETSI EN 304623					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s)	U/C	Condition
Part I: Security Properties of Products with Digital Elements					
1	Products designed with appropriate cybersecurity	Annex I, Part I, (1)	4.7.7, 4.7.8, 5.1, 5.2	U	
2	No known exploitable vulnerabilities	Annex I, Part I, (2)(a)	5.12.1, 5.12.2, 6.1	U	
3	Secure by default configuration	Annex I, Part I, (2)(b)	5.3	U	
4	Vulnerabilities addressable through updates	Annex I, Part I, (2)(c)	5.6.4, 5.12.2, 5.12.8	C	When update capability present (Clause 4.3.3.1)
5	Protection from unauthorized access	Annex I, Part I, (2)(d)	5.3.2, 5.4	C	When configuration capability present (Clause 4.3.3.3)
6	Confidentiality protection	Annex I, Part I, (2)(e)	5.5	U	
7	Integrity protection	Annex I, Part I, (2)(f)	5.6	U	
8	Data minimization	Annex I, Part I, (2)(g)	5.7	U	
9	Availability and resilience	Annex I, Part I, (2)(h)	5.8	U	
10	Minimize impact on other devices	Annex I, Part I, (2)(i)	5.9	C	When network boot source present (Clause 4.3.3.2)
11	Reduce attack surfaces	Annex I, Part I, (2)(j)	5.10	U	
12	Mitigate exploitation impact	Annex I, Part I, (2)(k)	5.2.3, 5.9	U	
13	Security-relevant recording/monitoring	Annex I, Part I, (2)(l)	5.11	C	When logging capability present (Clause 4.3.3.6)
14	Secure data/settings removal	Annex I, Part I, (2)(m)	5.5.7, 5.5.8	C	When configuration capability present (Clause 4.3.3.3)
Part II: Vulnerability Handling					
15	Identify and document vulnerabilities	Annex I, Part II, (1)	5.12.1, 6.1	U	
16	Address and remediate vulnerabilities	Annex I, Part II, (2)	5.6.4, 5.12.2, 5.12.8	C	When update capability present (Clause 4.3.3.1)
17	Regular security testing	Annex I, Part II, (3)	6.1	U	

Harmonised Standard ETSI EN 304623					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s)	U/C	Condition
18	Disclose fixed vulnerabilities	Annex I, Part II, (4)	5.12.2	U	
19	Coordinated vulnerability disclosure	Annex I, Part II, (5)	5.12	U	
20	Facilitate vulnerability information sharing	Annex I, Part II, (6)	5.12.1, 5.12.2	U	
21	Secure update distribution	Annex I, Part II, (7)	5.6.4, 5.12.7, 5.12.8, 5.12.9	C	When update capability present (clause 4.3.3.1)
22	Free security updates with advisory	Annex I, Part II, (8)	5.12.2	C	When update capability present (clause 4.3.3.1)

2288

2289 **Requirement:**2290 **No** A unique identifier for one row of the table which may be used to identify a requirement.2291 **Description** A textual reference to the requirement.2292 **Requirements of Regulation**

2293 Identification of article(s) defining the requirement in the Regulation.

2294 **Clause(s) of the present document**2295 Identification of clause(s) defining the requirement in the present document unless another
2296 document is referenced explicitly.2297 **Requirement conditionality:**2298 **U/C** Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the
2299 manufacturer's claimed functionality of the equipment (C)2300 **Condition** Explains the conditions when the requirement is applicable for a requirement which is classified
2301 "conditional"

2302

2303 Annex B (informative): 2304 Risk analysis for threat modeling

2305 B.1 Purpose and methodology

2306 B.1.1 General

2307 This annex provides detailed risk analysis to support manufacturers in conducting threat modeling.

2308 This annex provides risk analysis supporting the requirements framework defined in clause 5.

2309 Boot managers face unique challenges: pre-OS execution, establishment of platform trust, and extreme product
2310 diversity from 256-byte ROM code to full UEFI systems. This diversity makes deployment-scenario-based
2311 requirements impractical since manufacturers often cannot predict final deployment context.

2312 The standard uses a characteristic-based model where objective technical features determine which threats are relevant.
2313 Each product characteristic has dual security impact: it introduces additional attack surface requiring protective
2314 measures and enables security mechanisms that mitigate specific threats. For example, network update capability
2315 enables vulnerability remediation through network updates (mitigation) while requiring protection against
2316 network-based update attacks (additional risk). Requirements address both aspects.

2317 Risk factors (clause 4.7.8) characterize deployment context independently of product capabilities. Representative use
2318 cases (clause 4.8) provide typical risk factors. Risk level (LOW/MEDIUM/HIGH) affects requirement stringency where
2319 specified.

2320 B.1.2 Methodology approach

2321 This risk analysis uses three interconnected elements:

2322 **Assets (clause 4.7.6):** Nine categories requiring protection: code, configuration, runtime state, cryptographic material,
2323 measurements, audit logs, authentication credentials, update packages and rollback counters.

2324 **Threats (clause 4.7.7):** Six threat categories: T-INTEGRITY, T-PERSIST, T-PHYS, T-SUPPLY, T-NET, T-AVAIL.

2325 **Product capabilities (clause 4.3):** Technical features determining which threats are relevant and which security
2326 mechanisms are available.

2327 The analysis maps product characteristics to threat exposure:

- 2328 • Which threats become relevant based on technical features.
- 2329 • Which assets are impacted.
- 2330 • Risk implications for each characteristic.

2331 Each product characteristic sclause (B.1.3.1 through B.1.3.6) provides:

- 2332 • Relevant threats for each characteristic variant.
- 2333 • Assets affected.
- 2334 • Threat exposure analysis.
- 2335 • Risk implications for manufacturers.

2336 B.2 Threat identification methodology

2337 B.2.1 Development approach

2338 The threat taxonomy in clause B.3 was developed through analysis of documented attacks, security frameworks,
2339 regulatory requirements, and expert review.

2340 B.2.2 Threat sources

- 2341 • NIST SP 800-193 [i.19] Platform Firmware Resiliency Guidelines, Appendix A attack scenarios.
- 2342 • Threat frameworks: MITRE EMB3D, CAPEC, CWE firmware patterns.
- 2343 • Documented attacks, for example BlackLotus (CVE-2022-21894), BootHole (CVE-2020-10713), LogoFAIL
2344 (CVE-2023-40238), BootBandit (CVE-2022-34301).
- 2345 • CRA Annex I: Essential cybersecurity requirements for supply chain, updates, vulnerability handling.

2346 B.2.3 Categorization rationale

2347 Six threat categories separate attacks by vector and persistence mechanism. Categories reflect attack mechanisms while
2348 acknowledging sophisticated attacks combine multiple vectors.

2349 B.2.4 Limitations

2350 Taxonomy represents threats known at standard development.

2351 B.3 Threat catalogue

2352 B3.0 Introduction

2353 This clause provides the threat catalogue referenced by requirements in clause 5. Each threat is identified by a unique
2354 identifier. Threat relevance is determined by capability presence. Threat exposure level is determined by risk factor
2355 analysis per clause 4.7.8.

2356 NOTE: The "Mitigated by" column uses the following markers: RQ-CATEGORY-NNN: Requirement(s) that
2357 mitigate this threat.

2358 Threats marked [HW] or [PROC] are not addressable by boot manager software alone.

2359 B.3.1 T-INTEGRITY: Boot integrity attacks

2360 Boot integrity attacks target the authenticity and trustworthiness of boot components, attempting to execute
2361 unauthorized code, weaken security policies, bypass verification mechanisms, or exploit parsing and input validation
2362 weaknesses.

2363 B.3.1.1 Code execution attacks

2364 Attacks that achieve execution of unauthorized code during boot.

Table B.3.1.1-1: Code execution attacks

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-INTEGRITY-1	A-CODE	All products	Malicious boot component substitution	RQ-INTEGRITY-001, RQ-INTEGRITY-002, RQ-INTEGRITY-003
T-INTEGRITY-2	A-CODE	Verified boot	Signature verification bypass	RQ-INTEGRITY-001, RQ-INTEGRITY-002, RQ-INTEGRITY-009
T-INTEGRITY-3	A-CODE, A-UPDATE	Update capability	Malicious update injection	RQ-INTEGRITY-004, RQ-VULN-006, RQ-VULN-007, RQ-VULN-008
T-INTEGRITY-4	A-RUNTIME, A-CODE	All products	Runtime code modification	RQ-INTEGRITY-010, RQ-INTEGRITY-014

B.3.1.2 Configuration tampering

Attacks that modify security policies and boot settings to weaken protections.

Table B.3.1.2-1: Configuration tampering

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-INTEGRITY-5	A-CONFIG, A-RUNTIME	Configuration capability	Security policy weakening via configuration interface	RQ-AUTH-002, RQ-AUTH-003, RQ-AUTH-004, RQ-INTEGRITY-009, RQ-SURFACE-006
T-INTEGRITY-6	A-CONFIG	Configuration capability	Boot order manipulation to load attacker media	RQ-AUTH-002
T-INTEGRITY-7	A-CONFIG, A-CRYPT	Configuration and update capability	Trust anchor database modification	RQ-AUTH-001, RQ-CONFID-001
T-INTEGRITY-8	A-CONFIG, A-RUNTIME	Runtime update and configuration capability	Configuration TOCTOU exploitation	–
T-INTEGRITY-9	A-CONFIG	Recovery capability	Recovery configuration abuse	RQ-AVAIL-008, RQ-AVAIL-014, RQ-MINIMAL-003, RQ-SURFACE-006

B.3.1.3 Cryptographic compromise

Attacks targeting keys, certificates, and cryptographic material.

Table B.3.1.3-1: Cryptographic compromise

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-INTEGRITY-10	A-CRYPT	Software-only implementation	Key extraction via software attacks	[HW]
T-INTEGRITY-11	A-CRYPT	Configuration and update capability	Key injection/replacement via interfaces	RQ-AUTH-001
T-INTEGRITY-12	A-CRYPT	Verified and measured boot	Weak key generation from insufficient entropy	[HW]
T-INTEGRITY-13	A-CRYPT	Long lifetime	Cryptographic algorithm exploitation	RQ-INTEGRITY-021, RQ-INTEGRITY-022, RQ-AVAIL-013

B.3.1.4 Parser and input validation attacks

Table B.3.1.4-1: Parser and input validation attacks

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-INTEGRITY-14	A-CODE, A-RUNTIME	All products	Boot image and data format parsing vulnerabilities	RQ-SURFACE-004
T-INTEGRITY-15	A-CODE, A-CONFIG	Network boot	Network protocol parsing vulnerabilities	RQ-SURFACE-004, RQ-SURFACE-005
T-INTEGRITY-16	A-CRYPT	Verified boot	Certificate and cryptographic format parsing vulnerabilities	RQ-INTEGRITY-019
T-INTEGRITY-17	A-RUNTIME	All products	Boot phase state machine manipulation	RQ-SBD-004, RQ-SURFACE-001
T-INTEGRITY-18	A-CRYPT, A-CODE	Long lifetime, verified and measured boot	Cryptographic algorithm deprecation over extended deployment	RQ-INTEGRITY-021, RQ-INTEGRITY-022, RQ-AVAIL-013
T-INTEGRITY-19	A-CRYPT	Long lifetime, verified boot	Key compromise accumulation over extended periods	[HW], RQ-INTEGRITY-022

B.3.1.5 Rollback attacks

Attacks that install older, vulnerable versions of firmware or configuration.

Table B.3.1.5-1: Configuration tampering

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-INTEGRITY-20	A-ROLLBACK, A-CODE	Update capability	Forced version downgrade or anti-rollback bypass	RQ-INTEGRITY-017, RQ-INTEGRITY-018, RQ-DEFAULT-004
T-INTEGRITY-21	A-ROLLBACK	Update capability, software-only implementation	Version counter manipulation or reset	[HW], RQ-INTEGRITY-018
T-INTEGRITY-22	A-CONFIG	Configuration capability	Configuration rollback to insecure settings	RQ-INTEGRITY-017, RQ-LOG-001
NOTE: Products without update capability are immune to firmware rollback attacks but face elevated risk from vulnerability accumulation.				

B.3.2 T-PERSIST: Persistent firmware threats

Persistent firmware threats establish malware or compromise that survives operating system reinstallation, disk formatting, and traditional security remediation.

Table B.3.2-1: Persistent firmware threats

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-PERSIST-1	A-CODE	Fixed storage, removable media, external expansion	Bootkit installation in boot manager storage	RQ-INTEGRITY-005, RQ-INTEGRITY-006
T-PERSIST-2	A-CODE	Fixed storage, removable media	Boot image tampering in persistent storage	RQ-INTEGRITY-005, RQ-INTEGRITY-006
T-PERSIST-3	A-CONFIG	Recovery capability	Recovery mechanism compromise	RQ-AVAIL-008, RQ-AVAIL-014
T-PERSIST-4	A-MEASURE	Measured boot	Attestation data forgery to hide compromise	RQ-LOG-001, RQ-LOG-002, RQ-LOG-003
T-PERSIST-5	A-AUDIT	All products	Event log manipulation to hide evidence	RQ-LOG-002, RQ-LOG-004
T-PERSIST-6	A-CODE, A-CONFIG	Network boot	Network boot infrastructure compromise	RQ-INTEGRITY-014, RQ-INTEGRITY-016
T-PERSIST-7	A-RUNTIME, A-AUDIT	All products	Boot resource exhaustion preventing successful boot completion	RQ-AVAIL-003, RQ-AVAIL-004

B.3.3 T-PHYS: Physical attacks

Physical attacks require direct hardware access to extract secrets, modify hardware, inject faults, or manipulate components. Physical security context determines attack feasibility more than boot manager capabilities.

Table B.3.3-1: Physical attacks

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-PHYS-1	A-CRYPT, A-RUNTIME, A-CODE	Boot from external expansion, software-only implementation	DMA attacks via peripheral buses	RQ-SBD-003, RQ-CONFID-003
T-PHYS-2	A-RUNTIME, A-CODE	Software-only implementation, verified boot	Fault injection (voltage glitching, EM interference)	[HW]
T-PHYS-3	A-CRYPT, A-MEASURE	Hardware security storage	Hardware security component initialization attacks	[HW]
T-PHYS-4	A-CRYPT, A-AUTH	Hardware security storage, verified and measured boot	Side-channel key extraction (power, EM, timing)	[HW]
T-PHYS-5	A-CODE, A-CONFIG, A-CRYPT	Physical access	Hardware tampering and component modification	[HW]
T-PHYS-6	A-CODE, A-CONFIG	Fixed storage boot	Flash memory direct manipulation	[HW]
T-PHYS-7	A-CODE, A-CONFIG	Removable media boot	Removable media substitution	RQ-SBD-003, RQ-INTEGRITY-002
T-PHYS-8	A-CODE, A-CONFIG	External expansion boot	External storage device compromise	RQ-SBD-003, RQ-INTEGRITY-002
T-PHYS-9	A-CODE	Internal storage boot	ROM extraction via chip de-packaging	[HW]
T-PHYS-10	A-CODE, A-CRYPT, A-RUNTIME	Debug interface boot	Debug interface exploitation and authentication bypass	RQ-AUTH-001, RQ-SURFACE-001, RQ-SURFACE-002
T-PHYS-11	A-CRYPT, A-CODE	Debug interface boot	Memory and firmware extraction via debug interfaces	[HW]

B.3.4 T-SUPPLY: Supply chain attacks

Supply chain attacks compromise boot managers during manufacturing, development, distribution, or through systemic trust failures. These threats affect all products regardless of capabilities, though update mechanisms expand the attack surface.

Table B.3.4-1: Supply chain attacks

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-SUPPLY-1	A-CODE, A-CRYPT	All products	Manufacturing environment compromise	[PROC], RQ-DEFAULT-003, RQ-DEFAULT-001
T-SUPPLY-2	A-CODE	All products	Third-party component compromise	RQ-VULN-009
T-SUPPLY-3	A-CODE	All products	Development tool compromise (compiler attacks)	[PROC]
T-SUPPLY-4	A-CODE	Update capability	Distribution interception	[PROC]
T-SUPPLY-5	A-CODE, A-CRYPT	Update capability	Update infrastructure compromise	[PROC]
T-SUPPLY-6	A-CRYPT	Verified boot	Default or leaked platform keys	RQ-AUTH-001
T-SUPPLY-7	A-UPDATE	Update capability	Update tooling compromise	[PROC]
T-SUPPLY-8	A-CRYPT	Verified and measured boot	Trust anchor revocation failures	RQ-INTEGRITY-008, RQ-INTEGRITY-020

B.3.5 T-NET: Network-based attacks

Network-based attacks exploit network connectivity during boot, update, or configuration processes, providing remote attack surface. These attacks occur before operating system security mechanisms are active.

Table B.3.5-1: Network based attacks

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-NET-1	A-CODE, A-CONFIG, A-CRYPT	Network update capability	Man-in-the-middle and boot image tampering in transit	RQ-MINIMAL-002, RQ-INTEGRITY-004, RQ-INTEGRITY-015
T-NET-2	A-CODE, A-CONFIG	Network boot	Rogue DHCP/TFTP/HTTP boot servers	RQ-INTEGRITY-014, RQ-INTEGRITY-016, RQ-SURFACE-003
T-NET-3	A-CODE	Network update capability	Network protocol implementation vulnerabilities	RQ-MINIMAL-001, RQ-SURFACE-003
T-NET-4	A-CONFIG, A-AUTH	Remote configuration capability	Remote management interface exploitation	RQ-SURFACE-006, RQ-CONFID-004
T-NET-5	A-UPDATE	Network update capability	Update denial of service	RQ-IMPACT-001, RQ-AVAIL-004
T-NET-6	A-CONFIG, A-CRYPT, A-MEASURE	Network boot, Measured boot	Unauthorized disclosure of boot configuration, attestation, or cryptographic material via network	RQ-CONFID-007, RQ-LOG-005

B.3.6 T-AVAIL: Availability and resilience threats

Availability and resilience threats prevent successful boot completion, cause denial of service, or undermine recovery mechanisms that ensure operational continuity.

2406

Table B.3.6-1: Resilience threats

Threat ID	Affected Assets	Introduced by	Description	Mitigated by
T-AVAIL-1	A-CODE, A-CONFIG	Update capability	Update process causes denial of service through resource exhaustion or deadlock	RQ-VULN-009, RQ-AVAIL-011, RQ-AVAIL-012
T-AVAIL-2	A-RUNTIME, A-CONFIG	Network boot capability	Network boot resource exhaustion or infrastructure unavailability	RQ-AVAIL-003, RQ-AVAIL-004, RQ-AVAIL-005, RQ-AVAIL-009, RQ-AVAIL-010
T-AVAIL-3	A-CONFIG, A-RUNTIME	Configuration management	Boot configuration corruption preventing successful boot	RQ-AVAIL-001, RQ-AVAIL-013
T-AVAIL-4	A-CODE, A-RUNTIME	Multiple boot sources	Primary boot path failure without fallback mechanism	RQ-AVAIL-002, RQ-AVAIL-007
T-AVAIL-5	A-CONFIG, A-CODE	Recovery capability	Recovery mechanism unavailable or corrupted when needed	RQ-AVAIL-014, RQ-AVAIL-018
NOTE 1: Availability threats often interact with integrity threats (T-INTEGRITY) and persistence threats (T-PERSIST).				
NOTE 2: Many availability protections are reliability features (timeouts, retries, fallbacks) rather than direct security countermeasures. These requirements support recovery from attacks but are not mitigations in themselves				

2407

2408 Annex C (informative): 2409 Product Documentation

2410 C.1 Security design documentation

2411 **Threat modelling:** Documented threat modelling covering all threats in Annex B applicable to the product's
2412 capabilities.

2413 **Boot flow and trust boundaries:** Documentation of the complete boot flow from power-on to handoff, identifying trust
2414 boundaries between stages and the defence-in-depth approach.

2415 **Cryptographic architecture:** Documentation of the cryptographic key hierarchy, storage locations, and trust model.
2416 This includes key provisioning, lifecycle management, and identification of trust anchors.

2417 **Memory and interface architecture:** Documentation of memory layout, protection mechanisms, and interfaces
2418 exposed at each boot stage.

2419 **Recovery mechanisms:** Documentation of recovery and failsafe mechanisms, including recovery triggers, failsafe boot
2420 paths, and user notification.

2421 **Isolation boundaries:** Documentation of isolation boundaries between boot components, including the mechanisms
2422 employed and failure isolation properties.

2423 **Software Bill of Materials (SBOM):** Software bill of materials listing all third-party components with version
2424 information.

2425 C.2 Physical security documentation

2426 Documentation of physical security requirements when updates are not supported. This covers physical access control
2427 requirements, tamper detection expectations, and compensating controls for lack of update capability.

2428 C.3 Integrity mechanism documentation

2429 **Measurement process:** Documentation of the measurement process for validation, including measurement algorithm,
2430 sequence, storage, and validation method.

2431 **Environmental assumptions without hardware security:** Documentation of environmental assumptions for physical
2432 security when hardware security components are not available, including threat model limitations and deployment
2433 restrictions.

2434 C.4 Configuration security documentation

2435 Documentation of security impact for each configuration option, including recommended secure values and warnings
2436 for insecure configurations. Applies to boot managers with configuration capability.

2437 C.5 Vulnerability handling documentation

2438 **Update procedures:** Documentation of update procedures, or explicit statement that updates are not supported with
2439 rationale.

2440 **Compensating controls for non-updateable implementations:** Documentation of compensating controls and
2441 hardware replacement as the update mechanism when updates are not supported.

2442 **End-of-life guidance:** End-of-life guidance when vulnerabilities cannot be mitigated for non-updateable
2443 implementations, including decommissioning procedures.

2444 **Vulnerability mitigation scope:** Documentation of which vulnerabilities can be addressed via configuration versus
2445 code updates.

2446 C.6 Security testing evidence

2447 Evidence demonstrating the boot manager has undergone appropriate security validation.

2448 **Signature verification testing:** Evidence of testing valid signatures, invalid signatures, expired signatures, and revoked
2449 signatures.

2450 **Authentication mechanism testing:** Evidence of authentication bypass and privilege escalation testing.

2451 **Rollback protection testing:** Evidence of rollback attempt testing with older valid images and version counter
2452 manipulation.

2453 **Secure failure mode testing:** Evidence of testing behaviour under verification failure, resource exhaustion, and
2454 corrupted input.

2455 **Input fuzz testing:** Evidence of fuzz testing covering parsers for configuration, images, and certificates.

2456 **Memory safety testing:** Evidence of buffer overflow and integer overflow testing, including static and dynamic
2457 analysis.

2458 **Code review:** Evidence of security-focused code review.

2459 **Architecture review:** Evidence of architecture review against the documented threat model.

2460 **Binary analysis:** Evidence of binary analysis of production builds, including verification that debug symbols and test
2461 code are removed.

2462 **Supply chain security review:** Evidence of supply chain security review covering third-party components and build
2463 process.

2464 **Test coverage metrics:** Documentation of test coverage metrics for code, requirements, and threats.

2465 **Vulnerability remediation:** Evidence of remediation of vulnerabilities identified during testing.

2466 C.7 Documentation format

2467 Documentation shall be provided in a format accessible to conformity assessment bodies and maintained throughout the
2468 product support period.

2469

Annex D (informative): Vulnerability management considerations

NOTE: These considerations should inform manufacturer processes for vulnerability disclosure, response coordination, and security communication. Detailed vulnerability handling requirements will be defined in horizontal standard prEN 40000-1-3 [i.4].

Boot managers present unique challenges for vulnerability management due to their position in the system architecture and multi-stakeholder supply chain.

Extended remediation timelines: Boot manager vulnerabilities may require coordinated response across multiple parties:

- Silicon vendors for hardware root of trust or microcode updates
- Firmware developers for boot manager code patches
- OEMs for integration, testing, and distribution
- OS vendors for certificate or configuration updates
- End users or administrators for patch deployment

This multi-party coordination, combined with extensive testing requirements for critical boot code, results in significantly extended remediation timelines compared to application software. The timeline varies based on product complexity, supply chain structure, deployment context, and vulnerability severity.

Coordinated disclosure requirements: Due to the persistent and privileged nature of boot malware, vulnerability information needs to be carefully managed to prevent exploitation before patches reach end users. Coordinated disclosure processes should account for the extended timelines inherent in boot manager vulnerability remediation.

defence-in-depth importance: The extended vulnerability remediation timeline elevates the importance of defence-in-depth security controls during product design. Boot managers should implement multiple layers of security controls to reduce the impact of potential vulnerabilities, as rapid patching is not feasible for boot-level code.

Supply chain responsibility: In multi-stakeholder scenarios, manufacturers should document which parties are responsible for vulnerability monitoring, patch development, and deployment coordination. Clear communication channels and responsibility assignment are essential for effective vulnerability management.

Annex E (informative): Relation to NIST SP 800-193

E.1 Purpose

This annex maps requirements to the Protection/Detection/Recovery (PDR) framework from NIST SP 800-193 Platform Firmware Resiliency Guidelines.

NOTE 1: NIST SP 800-193 [i.19] defines Roots of Trust (RTU, RTD, RTRec) anchored in immutable hardware. These are out of scope per **clause 1.3**. Boot managers consume these roots but do not provide them.

NOTE 2: "Section" references throughout this annex refer to sections within NIST SP 800-193 [i.19], not clauses within the present document.

E.2 Protection (SP 800-193, Section 4.2)

E.2.1 Authenticated update mechanism (Section 4.2.1.1)

Table E.2.1-1: Authenticated update mechanism

Requirement	Description
RQ-VULN-002	Update mechanisms enabling vulnerability remediation
RQ-INTEGRITY-004	Verify authenticity and integrity of update packages
RQ-VULN-008	Execute update operations atomically
RQ-VULN-007	Store update verification keys in hardware security component
RQ-INTEGRITY-018	Enforce rollback protection
RQ-INTEGRITY-019	Store anti-rollback counters, verify signed version metadata

E.2.2 Integrity protection (Section 4.2.1.2)

Table E.2.2-1: Integrity protection

Requirement	Description
RQ-INTEGRITY-001	Verify integrity and authenticity using hashes and signatures
RQ-INTEGRITY-002	Prevent boot with unverified, invalid, expired, or revoked components
RQ-INTEGRITY-006	Maintain configurable list of approved signatures
RQ-INTEGRITY-009	Prevent unauthorized modification between verification and execution
RQ-INTEGRITY-010	Load components into protected memory before verification
RQ-AUTH-007	Protect trusted certificate stores from unauthorized modification
RQ-CONFID-008	Overwrite sensitive data after use
RQ-LOG-002	Protect measurement records from unauthorized modification

2513 E.2.3 Non-bypassability (Section 4.2.1.3)

2514 **Table E.2.3-1: Non-bypassability**

Requirement	Description
RQ-SBD-001	Isolate boot components using memory/privilege separation
RQ-SBD-002	Restrict access to cryptographic key material
RQ-SBD-003	Disable debug interfaces, revoke DMA access before handoff
RQ-SBD-004	Enforce privilege boundaries between boot stages
RQ-AUTH-001	Require physical presence for key/certificate changes
RQ-AUTH-002	Protect boot order and parameters from unauthorized modification
RQ-AUTH-003	Require authentication before weakening security defaults
RQ-AUTH-005	Verify cryptographic signature on security policy changes
RQ-INTEGRITY-002	Prevent boot continuation with unverified components
RQ-INTEGRITY-008	Require authentication before allowing verification bypass
RQ-DEFAULT-001	Enable cryptographic signature validation by default
RQ-DEFAULT-002	No default passwords, backdoors, or undocumented access
RQ-SURFACE-002	Disable debug interfaces and test modes in production

2515

2516 E.2.4 Protection of critical data (Section 4.2.4)

2517 **Table E.2.4-1: Protection of critical data**

Requirement	Description
RQ-SURFACE-0 06	Detect unauthorized config modifications, use checksums
RQ-INTEGRITY-012	Protect sensitive configuration with authenticated encryption
RQ-CONFID-004	Hash stored credentials

2518

2519 E.3 Detection (SP 800-193 Section 4.3)

2520 E.3.1 Detection of corrupted code (Section 4.3.1)

2521 **Table E.3.1-1: Detection of corrupted code**

Requirement	Description
RQ-LOG-001	Record measurements before execution
RQ-LOG-002	Protect measurement integrity
RQ-LOG-003	Provide measurement logs with freshness mechanisms
RQ-INTEGRITY-003	Check component provenance and version consistency
RQ-INTEGRITY-005	Detect unauthorized firmware modifications

2522

2523 E.3.2 Detection of corrupted critical data (Section 4.3.2)

2524 **Table E.3.2-1: Detection of corrupted critical data**

Requirement	Description
RQ-SURFACE-0 06	Detect unauthorized modifications to configuration
RQ-INTEGRITY-013	Restore secure defaults when corruption detected
RQ-LOG-001	Record measurements of boot components and configuration
RQ-LOG-002	Protect measurement records from tampering
RQ-LOG-004	Indicate security-relevant failures and state changes

2526 E.3.3 Notification

2527 **Table E.3.3-1: Notification**

Requirement	Description
RQ-DEFAULT-005	Provide user-visible indication when security is reduced
RQ-AUTH-006	Indicate when running with modified policies
RQ-AVAIL-018	Indicate errors with sufficient detail
RQ-LOG-003	Provide measurement records in verifiable format
RQ-LOG-004	Indicate security-relevant failures

2529 E.4 Recovery (SP 800-193 Section 4.4)

2530 E.4.1 Recovery of mutable code (Section 4.4.1)

2531 **Table E.4.1-1: Recovery of mutable code**

Requirement	Description
RQ-AVAIL-016	Halt boot, maintain integrity on failure
RQ-AVAIL-017	Enter recovery mode on security violations
RQ-AVAIL-003	Support redundant boot paths
RQ-AVAIL-005	Enforce timeouts for all operations
RQ-AVAIL-011	Require authentication for recovery mode
RQ-AVAIL-015	Protect recovery from unauthorized modification
RQ-AVAIL-01 8	Maintain recovery accessibility, preserve across updates
RQ-INTEGRITY-022	Support revocation of compromised keys

2533 E.4.2 Recovery of critical data (Section 4.4.2)

2534 **Table E.4.2-1: Recovery of critical data**

Requirement	Description
RQ-DEFAULT-006	Support restoration of secure defaults
RQ-CONFID-007	Cryptographically erase sensitive data during disposal
RQ-CONFID-008	Indicate successful sanitization completion
RQ-AVAIL-001	Support fallback to known-good configuration
RQ-AVAIL-012	Handle network boot failures with fallback
RQ-VULN-001	Provide version information accessible to OS

E.5 Firmware categories

NIST SP 800-193 [i.19] applies PDR to specific firmware categories. The present document applicability:

Table E.5-1: Firmware categories

SP 800-193 [i.19] Category	The present document Applicability
Platform firmware (BIOS/UEFI)	system firmware
Boot firmware	primary focus
Option ROMs	when boot-relevant
SMM firmware	when boot-relevant
Management controller	boot-related functions only
Network controller	network boot only

2541 Annex F (informative): 2542 Assessment guidance

2543 F.1 General

2544 This annex provides informative guidance for assessment activities. Assessment bodies may use alternative methods
2545 that satisfy the pass criteria in clause 6.

2546 F.2 Common verification approaches

2547 F.2.1 Documentation review

2548 Review manufacturer security documentation for:

- 2549 • Security architecture description.
- 2550 • Product capabilities and configuration options.
- 2551 • Threat model coverage.
- 2552 • Implementation specification.

2553 F.2.2 Functional verification

2554 Verify security mechanisms by:

- 2555 • Attempting protected operations without authorization.
- 2556 • Modifying protected assets and observing response.
- 2557 • Triggering failure conditions and observing recovery.
- 2558 • Examining logs for required entries.

2559 F.2.3 Resistance testing

2560 For HIGH risk assessments, verify resistance by:

- 2561 • Attempting bypass of authentication mechanisms.
- 2562 • Attempting rollback to previous versions.
- 2563 • Attempting trust anchor modification.
- 2564 • Attempting log tampering.
- 2565 • Fuzzing inputs and observing behaviour.

2566 F.3 Equipment considerations

2567 Boot manager assessment may benefit from:

- 2568 • Serial console access for boot sequence observation.

- 2569 • Debug interface access for state verification.
- 2570 • Logic analysers for timing analysis.
- 2571 • Platform-specific development tools.
- 2572 • Network protocol analysers for network boot testing.

2573 F.4 Test environment

2574 Recommended test environment includes:

- 2575 • Device in known initial state (factory default or documented baseline).
- 2576 • Valid and invalid credential sets.
- 2577 • Modified boot components for tampering tests.
- 2578 • Older firmware versions for rollback tests.
- 2579 • Network isolation for update testing.
- 2580 • Malformed input data for validation testing.

2581

2582

History

Version	Date	Status
V0.0.12	December 2025	Clean-up done by <i>editHelp!</i> E-mail: mailto:edithelp@etsi.org

2583